WOJSKOWA AKADEMIA TECHNICZNA
im. Jarosława Dąbrowskiego
WYDZIAŁ CYBERNETYKI



PRACA DYPLOMOWA

STACJONARNE STUDIA I STOPNIA

Temat: **PROJEKT I IMPLEMENTACJA SYSTEMU OCHRONY APLIKACJI INTERNETOWEJ Z WYKORZYSTANIEM ROZWIĄZAŃ FIRMY IMPERVA**

Autor:

Krystian WOJDYGOWSKI

Kierownik pracy:

dr inż. Zbigniew ŚWIERCZYŃSKI

W a r s z a w a 2015

Spis treści

Wstęp **6**

Rozdział 1.
Opis najważniejszych zagrożeń aplikacji internetowych **8**
1.1. Charakterystyka aplikacji internetowych **8**
1.2. Organizacja charytatywna OWASP **10**
1.3. Najpoważniejsze rodzaje zagrożeń bezpieczeństwa aplikacji internetowych **11**
1.3.1. Grupa zagrożeń Injection **11**
1.3.2. Grupa zagrożeń Broken Authentication and Session Management.. **13**
1.3.3 Grupa zagrożeń Cross-Site Scripting (XSS) **14**
1.3.4. Grupa zagrożeń Insecure Direct Object Reference **16**
1.3.5. Grupa zagrożeń Security Misconfiguration **17**
1.3.6. Grupa zagrożeń Sensitive Data Exposure **18**
1.3.7. Grupa zagrożeń Missing Function Level Access Control **20**
1.3.8. Grupa zagrożeń Cross-Site Request Forgery (CSRF) **21**
1.3.9. Grupa zagrożeń Using Components with Known Vulnerabilities .. **22**
1.3.10. Grupa zagrożeń Unvalidated Redirects and Forwards **23**

Rozdział 2.
Opis funkcji filtra aplikacyjnego w zakresie transmisji WWW realizowanych przez Imperva SecureSphere **25**
2.1. Firma Imperva i oferowane przez nią produkty **25**
2.2. Charakterystyka produktów firmy Imperva **26**
2.3. Charakterystyka produktów z grupy Web Application Security **27**

Rozdział 3.
Opracowanie wymagań na system służący do ochrony aplikacji webowej …. **33**
3.1. Analiza istniejącej infrastruktury teleinformatycznej **33**
3.2. Cel inwestycji **34**

3.3. Wymagania funkcjonalne na projektowany system **34**
3.4. Wymagania niefunkcjonalne na projektowany system **35**

Rozdział 4.
Opracowanie projektu systemu **36**
4.1. Wstępne testy penetracyjne zabezpieczanej aplikacji internetowej **36**
4.1.1. Badanie podatności aplikacji programem Vega **36**
4.1.2. Przeprowadzenie ataku z grupy Injection **37**
4.1.3. Przeprowadzenie ataku z grupy Cross-Site Scripting (XSS) **38**
4.2. Projekt systemu zabezpieczeń aplikacji internetowej **40**

Rozdział 5.
Implementacja systemu **43**
5.1. Konfiguracja serwera zarządzającego (MX) **43**
5.2. Konfiguracja bramy **44**
5.3. Dostosowanie wdrożonego systemu zabezpieczeń **47**

Rozdział 6.
Testowanie systemu **53**
6.1. Badanie podatności zabezpieczonej aplikacji internetowej programem Vega **53**
6.2. Próba wyświetlenia kodu błędu serwera **54**
6.3. Przeprowadzenie ataku z grupy Injection **55**
6.4. Przeprowadzenie ataku z grupy Cross-Site Scripting (XSS) **56**

Wnioski końcowe **57**
Bibliografia **59**

Wstęp

W dynamicznym rozwoju Internetu, rzutującym na współpracę ludzi oraz realizację istotnych i ważnych przedsięwzięć na całym świecie, znaczącą rolę odgrywają aplikacje internetowe. Postęp cywilizacyjny, w tym opracowywanie i wdrażanie nowych technologii, prowadzi do zmniejszenia zainteresowania użytkowników korzystaniem z aplikacji desktopowych na rzecz aplikacji webowych. Głównymi czynnikami determinującymi zwiększony popyt na omawiane aplikacje jest ich mobilność, a także powszechna dostępność.

Postępujący rozwój aplikacji internetowych wiąże się również z problemem dotyczącym bezpiecznego działania tych aplikacji. Warto zauważyć, że potencjalnych zagrożeń przy dużej dostępności tego typu aplikacji jest wiele i dlatego bardzo ważnym jest wyeliminowanie możliwości wykorzystania podatności tych aplikacji. W związku z tym, niezbędne jest opracowanie i wdrożenie systemu zabezpieczeń, który zagwarantuje wzrost poziomu bezpieczeństwa aplikacji webowej.

Podkreślić należy, że w literaturze przedmiotu uwaga skupiona jest najczęściej na analizie dynamicznego rozwoju nowych technologii, natomiast w mniejszym stopniu na skutecznym uniknięciu możliwości przejmowania poufnych informacji przez niepowołane osoby.

Celem pracy jest opracowanie projektu i implementacji systemu zabezpieczeń aplikacji internetowej w oparciu o produkty firmy Imperva. Podstawę rozważań stanowi identyfikacja zagrożeń, na które narażone są aplikacje internetowe oraz analiza funkcji i cech produktów wspomnianej firmy.

Zakres tematyczny pracy obejmuje sześć rozdziałów. Dwa pierwsze mają charakter teoretyczny, a kolejne cztery badawczy.

Rozdział pierwszy zawiera definicję pojęcia aplikacji internetowej, prezentację organizacji charytatywnej OWASP, a także wyszczególnienie i charakterystykę najczęściej występujących zagrożeń, na które narażone są wspomniane aplikacje internetowe.

Rozdział drugi obejmuje zestawienie podstawowych funkcji produktów oferowanych przez firmę Imperva i ich charakterystykę.

Rozdział trzeci zawiera opracowanie wymagań na system służący do ochrony aplikacji internetowej. Podstawę rozważań poprzedza analiza istniejącej infrastruktury teleinformatycznej, wewnątrz której wdrożona zostanie omawiana aplikacja internetowa.

Przedstawienie procesu wstępnej analizy podatności aplikacji internetowych na potencjalne ataki, a także opracowanie projektu systemu zabezpieczeń stanowi treść rozdziału czwartego.

Rozdział piąty stanowi proces wdrożenia omawianego systemu zabezpieczeń, na który składa się konfiguracja oraz dostosowanie produktu firmy Imperva celem zabezpieczenia aplikacji internetowej.

W rozdziale szóstym przedstawiony jest przebieg testów wdrożonego systemu zabezpieczeń oraz uzyskane wyniki badań.

Rozdział 1

Opis najważniejszych zagrożeń aplikacji internetowych

1.1. Charakterystyka aplikacji internetowych

Punktem wyjścia do rozważań na temat aplikacji internetowej powinno być precyzyjne określenie tego pojęcia, które byłoby możliwie najbardziej zgodne z definicją i jednocześnie z jej potocznym znaczeniem. W literaturze przedmiotu dotychczas nie wypracowano jednolitego i wspólnego dla różnych dziedzin informatyki określenia dla terminu „aplikacja internetowa". Trudno jest również jednoznacznie odpowiedzieć na pytanie, kiedy i w jakim znaczeniu użyto go po raz pierwszy. Według wielu źródeł, aplikacja internetowa (ang. *web application*), zwana również aplikacją webową, jest programem komputerowym, pracującym na serwerze i komunikującym się z użytkownikiem z wykorzystaniem przeglądarki internetowej. Należy zaznaczyć, że aplikacja webowa posiada dużo szersze znaczenie niż zwykła strona WWW, ze względu na interakcję z użytkownikiem.

Aplikacja internetowa bardzo często składa się również z bazy danych i szeregu usług dodatkowych, często rozproszonych, tj. umiejscowionych na wielu niezależnych od siebie serwerach. Takimi aplikacjami mogą być m.in. serwisy społecznościowe czy sklepy internetowe.

Ogromną zaletę omawianej aplikacji stanowi to, że daje ona możliwość dostępu do niej z praktycznie dowolnego miejsca na kuli ziemskiej, w którym znajduje się Internet, tym bardziej, że nie powoduje konieczności jej instalowania na komputerze, co zapewnia mobilność i komfort pracy.

Należy również zaznaczyć, że aplikacje webowe nie są uzależnione od systemów operacyjnych. Stąd wynika możliwość współpracy aplikacji na urządzeniu z innym systemem, zaś dzięki wykorzystaniu serwerów WWW i przeglądarki internetowej, z aplikacji webowej można skorzystać na każdym komputerze w innym dziale zakładu (firmy), mieście lub kraju.

Kolejnym istotnym zagadnieniem jest kwestia aktualizacji, którą dokonuje administrator aplikacji na serwerze, na którym jest ona przechowywana, dzięki czemu zapewniona jest możliwość na każdym z komputerów skorzystania z jej najaktualniejszej wersji.

W rozważaniach dotyczących aplikacji internetowej należy wspomnieć o bezpieczeństwie danych użytkownika. Jest to o tyle istotne, że aplikacje webowe potencjalnie mogą stać się obiektem zainteresowania np. hakerów. W związku z tym należy pamiętać, że nieostrożne logowanie się do takiej aplikacji (np. z kafejki internetowej) może spowodować przedostanie się danych użytkownika w niepowołane ręce, na co twórcy aplikacji nie mają wpływu. W związku z tym należy mieć na uwadze fakt, że korzystanie z aplikacji internetowych, choć w należyty sposób zabezpieczonych, wymaga również przestrzegania zasad bezpieczeństwa i odpowiedzialności ze strony użytkownika. Przestrzeganie tych zasad pozwoli na pełne wykorzystanie funkcji i cech, jakimi charakteryzują się poszczególne aplikacje.

Dynamiczny rozwój Internetu rzutuje na współpracę ludzi na całym świecie. Warto zauważyć, że obecnie dominujący jest podział użytkowników sieci na dwie podstawowe grupy:

- użytkownicy prywatni, korzystający z Internetu z domowych komputerów,
- użytkownicy biznesowi w szerokim znaczeniu tego słowa.

W realizacji istotnych i ważnych przedsięwzięć dla społeczności na całym świecie znaczącą rolę odgrywają aplikacje internetowe, ponieważ:

- cechują się wysoką dostępnością,
- korzystanie z aplikacji internetowych nie jest skomplikowane, gdyż praktycznie do ich obsługi wystarczy dostęp do urządzenia połączonego z Internetem,
- aplikacje internetowe zapewniają możliwość ich sukcesywnego rozbudowywania o dodatkowe funkcje w zależności od indywidualnych, specyficznych potrzeb użytkowników, bez konieczności wprowadzania zmian po stronie systemu użytkownika aplikacji,
- aplikacje internetowe są niezależne od systemów i przeglądarek korzystających z nich użytkowników,
- aplikacje internetowe zapewniają użytkownikom wysoki stopień bezpieczeństwa, ponieważ ich bazy danych są składowane oraz zabezpieczone centralnie.

Podkreślić należy, że w literaturze przedmiotu uwaga skupiona jest najczęściej na analizie dynamicznego rozwoju nowych technologii, wykorzystaniu w wielu dziedzinach nauki i życia społecznego komputerów oraz wszelkich urządzeń elektronicznych najnowszej generacji. Natomiast ze znacznie mniejszym zainteresowaniem traktowana jest tematyka dotycząca skutecznego uniknięcia możliwości przejmowania poufnych informacji przez niepowołane osoby. W dalszym ciągu, mimo stałego rozwoju systemów zabezpieczeń aplikacji internetowych, istnieje wysokie ryzyko ingerencji niepowołanych osób w celu dotarcia do danych gromadzonych lub przesyłanych przez użytkowników. Może to powodować bardzo poważne skutki, nie tylko finansowe.

1.2. Organizacja charytatywna OWASP

Rozważania na temat ewentualnych zagrożeń i zagwarantowania bezpieczeństwa aplikacji internetowych należy rozpocząć od precyzyjnego zdefiniowania tych zagrożeń, na które narażone są wspomniane aplikacje. W literaturze przedmiotu spotyka się poglądy prezentowane przez autorów publikacji, pracujących w ramach organizacji OWASP (ang. *Open Web Application Security Project*) [1]. Portal OWASP rozpoczął działalność 1-go grudnia 2001 r., natomiast status tej organizacji charytatywnej został nadany dnia 21 kwietnia 2004 r.

Warto zauważyć, że fundacja zrzesza osoby zainteresowane zabezpieczeniami oprogramowania. Umożliwia to zachowanie obiektywizmu w przekazywaniu informacji dotyczących bezpieczeństwa aplikacji, ponieważ omawiana fundacja nie jest związana z żadną komercyjną firmą zajmującą się rozwojem technologii tych zabezpieczeń. Podkreślić należy, że wszelkie materiały dostępne w serwisie OWASP, publikowane są w ramach licencji open-source. Jest to bardzo istotne z tego względu, że w myśl definicji omawianej licencji, zapewnia ona użytkownikom prawo do legalnego i bezpłatnego kopiowania, rozpowszechniania, modyfikacji, a także ulepszania i rozbudowy istniejących materiałów.

1.3. Najpoważniejsze rodzaje zagrożeń bezpieczeństwa aplikacji internetowych

W 2013 r. został po raz kolejny opublikowany dokument pt. „OWASP Top 10", w którym autorzy zaprezentowali i zdefiniowali 10 najpoważniejszych rodzajów zagrożeń bezpieczeństwa aplikacji internetowych. Zestawienie tych zagrożeń przedstawia się następująco:

- Injection.
- Broken Authentication and Session Management.
- Cross-Site Scripting (XSS).
- Insecure Direct Object References.
- Security Misconfiguration.
- Sensitive Data Exposure.
- Missing Function Level Access Control.
- Cross-Site Request Forgery (CSRF).
- Using Components with Known Vulnerabilities.
- Unvalidated Redirects and Forwards.

Z punktu widzenia niniejszej pracy za zasadne uznaje się przedstawienie charakterystyki każdego z wymienionych zagrożeń.

1.3.1. Grupa zagrożeń Injection

Grupa zagrożeń *Injection*, charakteryzuje się wykorzystywaniem podatności aplikacji na ataki oparte o przekazywanie szkodliwych danych do tej aplikacji przez atakującego. Przykładem ataku należącego do wspomnianej grupy zagrożeń jest SQL Injection. Atak ten, cechuje się umieszczaniem takich kodów w treści zapytań do bazy danych, które w praktyce, pozwalają na wykorzystanie interfejsu użytkownika w celu wprowadzenia spreparowanego ciągu znaków do aplikacji, tak aby zostały one przekazane dalej celem nieautoryzowanego wykonania. Warto zauważyć, że treść wspomnianego ciągu znaków jest w dużej mierze zależna od architektury atakowanej aplikacji. Co bardzo istotne, wiele aplikacji internetowych, nie posiada odpowiednio zaimplementowanej walidacji danych wejściowych, co znacznie zwiększa podatność tychże aplikacji na ataki z grupy *injection*. Mając na uwadze powyższe, danymi wejściowymi może być gotowe zapytanie języka SQL lub odwo-

łanie do procedury składowanej, która pozwala samoczynnie utworzyć gotowe zapytanie SQL. Należy także podkreślić, że w przypadku niektórych konfiguracji aplikacji korzystających z bazy danych istnieje możliwość wprowadzenia ciągu danych, składającego się z kilku zapytań SQL.

Na szczególną uwagę zasługuje fakt, że modyfikacja zapytań bazodanowych jest najczęstszym rodzajem ataku z grupy *injection*. Warto rozróżnić także inne, choć rzadziej występujące ataki tego rodzaju. Poniżej zaprezentowano ich zestawienie:

- OS Injection – wywoływanie poleceń systemowych wykorzystując podatną aplikację internetową.
- Code Injection – wprowadzanie kodu wykonywalnego do aplikacji, który zostanie wykonany przez interpreter tej aplikacji.
- Hibernate Injection – niewłaściwe korzystanie z zapytań HQL (ang. *Hibernate Query Language*), umożliwia modyfikację dynamicznie tworzonych zapytań celem wykonania dowolnego zapytania SQL.

Warto wskazać, że zdiagnozowanie podatności aplikacji internetowej na ataki z grupy *injection* jest znacznie łatwiejsze w przypadku analizy kodu źródłowego omawianej aplikacji, niż z użyciem testów penetracyjnych. Warto również zauważyć, że w przypadku zastosowania wspomnianych testów penetracyjnych, znacznie trudniej jest opracować atak wykorzystujący wykrytą podatność omawianej aplikacji.

Ataki należące do grupy *injection* są atakami powszechnymi, co wynika z popularności aplikacji internetowych wykorzystujących bazy danych. W wyniku przeprowadzenia ataku tego rodzaju, nieuprawniona osoba uzyskuje dostęp do danych użytkownika, a dodatkowo ma możliwość ich modyfikacji. Warto wskazać, że osoba atakująca, poza dostępem do wrażliwych informacji i możliwością ich modyfikacji, posiada jednocześnie możliwość nieodwracalnego ich usunięcia. W zasadzie każde z tych działań może być przyczyną bardzo poważnych konsekwencji np. finansowych dla właściciela danych, czy też strony WWW, na którą atak został przeprowadzony.

Warto wspomnieć o sposobie zabezpieczenia aplikacji internetowej przed atakami z grupy *injection*. Bardzo istotny jest fakt, że problem dotyczący bezpieczeństwa omawianej aplikacji powinien zostać poruszony już na etapie projektowania mechanizmów zabezpieczających tę aplikację. Według autorów publikacji „OWASP Top 10" należy wykorzystywać API (ang. *Application Programming Interface*), które umożliwi uniknięcie korzystania z dynamicznie generowanych zapytań do bazy danych. Warto wspomnieć, że omawiane zapytania, mogą być zastąpione np. zapytaniami parametryzowanymi (ang. *parameterized statement*), bądź też właściwie zaimplementowanymi procedurami składowanymi (ang. *stored procedure*). Należy także zaznaczyć, że implementacja interpretera traktującego znaki specjalne występujące w ciągu znaków, jako znaki pozbawione ich specjalnego znaczenia pozwala znacząco zmniejszyć ryzyko wystąpienia ataku z grupy *injection*. Według autorów omawianej publikacji, istnieje również możliwość poprawy bezpieczeństwa aplikacji internetowej poprzez implementację białej listy (ang. *white list*). Takie działanie pozwala na dokładne sprecyzowanie np. ilości wymaganych znaków specjalnych, z których będzie się składał ciąg znaków przekazywany do aplikacji jako parametr.

1.3.2. Grupa zagrożeń Broken Authentication and Session Management

Grupa zagrożeń *Broken Authentication and Session Management*, charakteryzuje się wykorzystywaniem błędnej implementacji mechanizmów aplikacji związanych z uwierzytelnianiem oraz zarządzaniem sesjami. W przypadku aplikacji internetowych, których praca wymaga korzystania z bezstanowego protokołu HTTP (ang. *Hypertext Transfer Protocol*), dane identyfikujące aktualnie zalogowanego użytkownika przesyłane są do serwera przy każdym odwołaniu do strony WWW. Warto zauważyć, że w przypadku braku wykorzystania protokołu SSL (ang. *Secure Socket Layer*), dane przesyłane są w postaci niezaszyfrowanej. Jest to bardzo istotne, ponieważ pozwala na ich zrozumiałe podsłuchanie przez nieupoważnione osoby. W przypadku skutecznego ataku tego typu, może dojść do zalogowania nieupoważnionej osoby do serwisu na prawach autoryzowanego użytkownika (ofiary) np. administratora systemu informatycznego. W omawianej sytuacji następuje uzyska-

nie uprawnień do korzystania z funkcji serwisu i obsługiwanych przez niego danych.

Warto zauważyć, że podatność aplikacji na ataki należące do omawianej grupy nie jest wyłącznie spowodowana błędami w implementacji, czy konfiguracji oprogramowania. Należy wskazać, że wpływ na jej bezpieczeństwo mają również niewłaściwie opracowane procedury, a także błędy organizacyjne.

Wady aplikacji w tym zakresie są przyczyną bardzo poważnych ryzyk dla całego systemu informatycznego. W przypadku uzyskania dostępu do danych użytkownika przez niepowołaną osobę istnieje duże ryzyko, kradzieży poufnych informacji, ich modyfikacji czy też trwałego ich usunięcia.

Co bardzo istotne, w celu zmniejszenia ryzyka wystąpienia ataku z omawianej grupy ataków, przede wszystkim należy zastosować się do zaleceń zdefiniowanych przez fundację OWASP w opracowaniu pt. „*Application Security Verification Standard (ASVS)*", które porusza kwestie związane ze sposobem uwierzytelniania użytkownika oraz zarządzania jego sesją. W omawianym dokumencie, autorzy zawarli m.in. zalecenia takie jak[2]:

- weryfikacja, czy sesje są unieważniane przy wylogowaniu użytkownika,
- weryfikacja czy wszystkie strony oraz zasoby wymagają uwierzytelnienia za wyjątkiem tych, które mają być dostępne publicznie,
- weryfikacja czy wszystkie mechanizmy uwierzytelniania są egzekwowane po stronie serwera,
- weryfikacja czy wszystkie strony, do których dostęp wymaga uwierzytelnienia zawierają linki umożliwiające wylogowanie.

Weryfikacja zabezpieczeń aplikacji zgodnie z zaleceniami przedstawionymi w omawianym dokumencie, pozwoli na zmniejszenie jej podatności na ataki z grupy *Broken Authentication and Session Management* już w fazie projektowania.

1.3.3. Grupa zagrożeń Cross-Site Scripting (XSS)

Kolejną grupą zagrożeń przestawioną w serwisie OWASP jest *Cross-Site Scripting (XSS)*. Grupa tych ataków charakteryzuje się tym, że przeprowadzane są one poprzez umieszczenie w serwisie internetowym złośliwego skryptu. Warto

podkreślić, że w tym celu wykorzystywany jest najczęściej *javascript*, bądź też *VBscript*. Takie zachowanie, pozwala na modyfikację stron webowych serwisu. Dane przygotowane przez atakującego, powodują zmianę logiki po stronie serwerowej portalu, podobnie jak w przypadku ataków z grupy *injection*. Należy przy tym zaznaczyć, że zmiana treści wyświetlanej przez serwer, następuje po stronie użytkownika końcowego, a nie po stronie agresora (osoby dokonującej ataku).

Co bardzo istotne, podatność aplikacji internetowej na ataki XSS, występuje wtedy, gdy dane od użytkowników przekazywane są do serwera bez weryfikacji, po czym zostają wyświetlone na stronach wynikowych. Można zatem stwierdzić, że przesyłane dane, zostają zwrócone do użytkownika w postaci aktywnej treści, która jest interpretowana przez przeglądarkę internetową podczas operacji renderowania strony.

Należy także podkreślić, że ataki należące do grupy XSS mogą zostać przeprowadzone poprzez umieszczenie kodu *javascript* w linku bezpośrednim do serwisu WWW. W przypadku wprowadzenia odpowiednio spreparowanego adresu w oknie przeglądarki, użytkownik nieświadomie przekazuje kod wykonujący *javascript* do aplikacji. W odpowiedzi zostaje przekazana użytkownikowi strona wynikowa, zawierająca wcześniej przesłany kod *javascript*, co powoduje wykonanie omawianego kodu w oknie przeglądarki po stronie klienta.

Podatność aplikacji internetowej na ataki z grupy XSS może być przyczyną bardzo poważnych konsekwencji dla użytkownika. Jednym ze skutków błędnej implementacji zabezpieczeń przed tego rodzaju atakami jest możliwość przechwytywania sesji użytkownika. Warto podkreślić, że istnieje wówczas możliwość uzyskania pełnego dostępu do serwisu na prawach użytkownika, bez konieczności poznania jego loginu oraz hasła. Niezależnie od omówionej sytuacji, istnieje również możliwość przekierowania przeglądarki użytkownika na inny adres internetowy, a także podmianę lub wstawienie dowolnej treści na stronę internetową.

W celu zabezpieczenia aplikacji przed atakami z grupy XSS, przede wszystkim należy unikać generowania strony wynikowej w oparciu o aktywną treść, która może zostać umieszczona przez atakującego np. w formularzu, umożliwiającym pozostawienie wpisu na stronie internetowej. Warto wspomnieć, że kolejną z me-

tod, która umożliwia zmniejszenie podatności aplikacji na atak z omawianej grupy, jest podobnie jak w przypadku ataków typu *injection*, zastosowanie białej listy. Taki rodzaj walidacji, można uzupełnić o mechanizm kontroli wykorzystywanych znaków, długości oraz formatu ciągu tych znaków, co znacznie poprawia bezpieczeństwo aplikacji internetowej.

1.3.4. Grupa zagrożeń Insecure Direct Object References

Kolejna grupa zagrożeń o nazwie *Insecure Direct Object References* cechuje się wykorzystywaniem luk w zabezpieczeniach aplikacji, w której występują m.in. zróżnicowane poziomy uprawnień. W przypadku aplikacji o takiej strukturze, istnieje ryzyko powstania problemu wynikającego z uzyskania bezpośredniego dostępu do obiektów systemowych. Należy podkreślić, że bardzo często, przyczyną jest błędna implementacja pewnych funkcji aplikacji. Pozorna niejawność identyfikatorów obiektów bazodanowych nie jest wystarczającą metodą kontroli dostępu do tych obiektów. W przypadku automatycznie generowanych identyfikatorów przez aplikację, obiekty posiadają indywidualne nazwy, które są nadawane zgodnie z pewnym schematem.

Niepoprawnie zaimplementowany mechanizm kontroli uprawnień użytkownika na poziomie funkcji przyjmującej identyfikator obiektu, bądź też brak tego mechanizmu, pozwoli użytkownikowi na wykonywanie tych samych operacji na obiektach, których jest właścicielem, jak również na obiektach, do których posiada wyłącznie identyfikator. Warto zauważyć, że jest to podatność aplikacji, która może umożliwić nieautoryzowany dostęp do danych użytkowników, korzystających z omawianej aplikacji.

Omawiając metody zabezpieczenia aplikacji internetowej, przed atakami należącymi do grupy zagrożeń o nazwie *Insecure Direct Object References*, przede wszystkim należy wspomnieć o używaniu pośredniego odwołania do obiektu przez użytkownika, bądź sesję. Według autorów publikacji „OWASP Top 10”, pozwala to na uniknięcie sytuacji, w której atakujący uzyskuje bezpośredni i nieautoryzowany dostęp do wrażliwych zasobów. W omawianej publikacji, podany został przykład wykorzystania rozwijanej listy, zawierającej zasoby do korzysta-

nia z których upoważniony jest zalogowany użytkownik. Każdy z elementów tej listy posiada przypisaną liczbę, która wskazuje wartość wybraną przez użytkownika. Wówczas aplikacja na tej podstawie, jest w stanie wygenerować dla użytkownika pośrednie odniesienie do obiektu na serwerze. Warto również zaznaczyć, że w przypadku każdej próby bezpośredniego odwołania do obiektu, należy dokonywać sprawdzania praw dostępu tak, aby uniknąć nieautoryzowanego dostępu do zasobu przechowywanego na serwerze.

1.3.5. Grupa zagrożeń Security Misconfiguration

W przypadku grupy zagrożeń *Security Misconfiguration*, przeprowadzane ataki na podatność aplikacji internetowych charakteryzują się wykorzystaniem luk w zabezpieczeniach spowodowanych błędną konfiguracją systemu, a także jego komponentów. Co bardzo istotne, ryzyko związane z omawianym problemem, nie jest spowodowane wyłącznie samą aplikacją. Warto wskazać, że dotyczy ono wszystkich elementów składających się na całość systemu tj. systemu operacyjnego, silników baz danych, a także serwerów aplikacyjnych.

Jedną z głównych przyczyn podatności aplikacji na zagrożenia należące do omawianej grupy, jest brak, bądź źle zdefiniowane procedury aktualizacji oprogramowania. Systematyczność instalacji uaktualnień jest bardzo istotna z punktu widzenia zabezpieczeń systemu informatycznego, ponieważ pozwala ona wyeliminować ewentualne luki, które umożliwiają przeprowadzenie ataku na aplikację internetową.

Należy także podkreślić istotne znaczenie polityki dostępów w przypadku, gdy zostanie ona niepoprawnie zaprojektowana. Poważne zagrożenie dla bezpieczeństwa aplikacji, stanowić może sposób dostępu do konsoli administracyjnej serwera. Warto nadmienić, że jest to spowodowane sytuacją, w której dostęp to wspomnianej konsoli możliwy jest z sieci wewnętrznych, jak również zewnętrznych.

Na szczególną uwagę zasługuje fakt, jak istotne znaczenie stanowi poprawna konfiguracja systemu informatycznego. Bardzo znaczące jest to, aby w ramach pracy serwera, na którym uruchomiona jest aplikacja webowa, wszelkie zbędne moduły czy usługi zostały wyłączone. W przeciwnym razie istnieje zwiększone ryzyko

wykrycia luki w systemie zabezpieczeń serwera, ponieważ potencjalne błędy w uruchomionych modułach mogą stanowić „punkt nieautoryzowanego wejścia" do tego systemu. Wpływ na bezpieczeństwo omawianej aplikacji może mieć również niepoprawne zabezpieczenie komunikacji pomiędzy poszczególnymi modułami, bądź też usługami składającymi się na całość systemu.

Biorąc pod uwagę powyższe informacje dotyczące grupy zagrożeń Security Misconfiguration, można przyjąć, że ryzyko wynikające z podatności aplikacji na tego rodzaju ataki, jest bardzo wysokie, ponieważ podobnie jak w przypadku uprzednio zdefiniowanych grup zagrożeń, istnieje możliwość nieautoryzowanego dostępu do danych użytkownika, przechowywanych na serwerze aplikacji.

Jednym ze sposobów zabezpieczenia aplikacji internetowej przed atakami wykorzystującymi błędną bądź niekompletną konfigurację systemu zabezpieczeń omawianej aplikacji jest wdrażanie nowych poprawek bądź aktualizacji do systemu informatycznego w możliwie jak najkrótszym czasie od chwili ich publikacji. Warto również wspomnieć o możliwości przeprowadzania skanowania aplikacji pod kątem jej podatności na różnego rodzaju ataki oraz okresowego dokonywania audytu w celu wykrycia przyszłych braków w konfiguracji, czy też instalacji niezbędnych poprawek aplikacji.

1.3.6. Grupa zagrożeń Sensitive Data Exposure

Grupa zagrożeń *Sensitive Data Exposure*, dotyczy przeprowadzania ataku na dane, które są niewystarczająco zabezpieczone, a które mają szczególnie wysokie znaczenie dla celów biznesowych systemu. Warto wskazać, że omawiane dane, o najwyższym znaczeniu dla użytkownika, powinny być chronione w możliwie jak najlepszym stopniu, wykorzystując w tym celu np. silne mechanizmy kryptograficzne.

Należy zwrócić szczególną uwagę na fakt, że wśród informacji posiadających najwyższy priorytet ochrony powinny znaleźć się następujące dane:

- dane finansowe (np. numery kart kredytowych, numery rachunków bankowych),
- dane uwierzytelniające (dane o kontach użytkowników),

- dane konfiguracyjne,
- dane administracyjne,
- dane biznesowe,
- dane wymagające specjalnej ochrony w świetle prawa (np. dane osobowe).

Zagrożenie przeprowadzenia ataku należącego do omawianej grupy, jest stosunkowo trudne do wykrycia i równocześnie wykorzystania przez atakującego. W celu przeprowadzenia ataku z wykorzystaniem tego rodzaju podatności należy najpierw dotrzeć do wnętrza systemu. Warto wspomnieć o tym, że dopiero w tym przypadku, atakujący uzyskuje dostęp do kluczowych informacji.

Zignorowanie bezpieczeństwa danych mających wysokie znaczenie dla systemu, jak i sfery biznesu może być przyczyną bardzo poważnych konsekwencji. Wykonanie udanego ataku przez nieuprawnioną osobę na system informatyczny oraz przejęcie nad nim całkowitej kontroli, bądź kradzież bardzo wrażliwych danych, może być przyczyną późniejszych problemów (nie tylko natury finansowej) zaatakowanej firmy.

W celu zabezpieczenia aplikacji internetowej przed zagrożeniami należącymi do grupy *Sensitive Data Exposure*, autorzy publikacji „OWASP Top 10” zalecają, by w przypadku wykorzystywania bardzo wrażliwych danych postępować zgodnie z niżej przedstawionymi punktami:

- należy się upewnić, że sposób szyfrowania danych transportowanych bądź przechowywanych na serwerze zapewnia wystarczający poziom bezpieczeństwa,
- należy zadbać o to, aby hasła wykorzystywane w systemie były przechowywane z pomocą silnego algorytmu szyfrującego, zaprojektowanego w tym celu np. *bcrypt*,
- należy wyłączyć autouzupełnianie formularzy przechowujących wrażliwe dane oraz wyłączyć buforowanie stron zawierających te dane,
- wrażliwe dane nie powinny być przechowywane jeśli nie jest to konieczne. Należy je usunąć tak szybko jak jest to możliwe, ponieważ pozwoli to na uniknięcie ich kradzieży.

Zastosowanie się do powyższych zaleceń, pozwala w znacznym stopniu zminimalizować ryzyko nieautoryzowanego dostępu do danych przechowywanych na serwerze aplikacji internetowej.

1.3.7. Grupa zagrożeń Missing Function Level Access Control

Kolejną grupą zagrożeń przestawioną w publikacji pt. „OWASP Top 10 for 2013" jest grupa o nazwie *Missing Function Level Access Control*. Zagrożenia aplikacji internetowej, należące do omawianej grupy dotyczą autoryzacji, tzn. zabezpieczenia przed niepowołanym dostępem do zasobów przeznaczonych dla użytkowników oraz uwierzytelniania, czyli przypadku, w którym część systemu dostępna jest dla wszystkich użytkowników, natomiast pozostała część wyłącznie dla użytkowników zalogowanych.

W przypadku ataków wykorzystujących podatność aplikacji internetowej na zagrożenia należące do wspomnianej grupy, wykorzystuje się możliwość nieupoważnionego dostępu do poszczególnych ekranów tej aplikacji. Należy przy tym zaznaczyć, że spowodowane jest to zarówno problemem konfiguracji systemu, jak również błędami programistów, a także architektury rozwiązania nie spełniającej podstawowych wymogów bezpieczeństwa. Warto wskazać, że błędy tego rodzaju, można zauważyć, w przypadku aplikacji, które realizują strategię autoryzacji uprawnień do poszczególnych zasobów poprzez ukrywanie odnośników do kolejnych ekranów wymagających innych uprawnień niż te, którymi aktualnie dysponuje zalogowany użytkownik.

Co bardzo istotne, zastosowanie omawianego rozwiązania w trakcie tworzenia aplikacji, powoduje bardzo wysokie ryzyko przeprowadzenia skutecznego ataku, ponieważ znajomość odpowiedniego adresu URL (ang. *Uniform Resource Locator*) wystarczy, aby atakujący uzyskał nieautoryzowany dostęp do przechowywanych zasobów użytkownika.

Na uwagę zasługuje sposób zabezpieczenia aplikacji internetowej przed zagrożeniem wynikającym z błędnie zaimplementowanego systemu autoryzacji, czy uwierzytelniania. W przypadku projektowania omawianej aplikacji, należy zwrócić szczególną uwagę na proces zarządzania uprawnieniami dostępu do zasobów przez

poszczególnych użytkowników systemu. Co bardzo istotne, mechanizm zarządzania uprawnieniami dostępu, powinien zapewniać łatwość ich aktualizacji. Warto wskazać, że zaimplementowane mechanizmy ochrony, powinny domyślnie odmawiać dostępu do przechowywanych danych, w przypadku gdy nie zostały określone inne reguły, pozwalające na ten dostęp. Pozwoli to na uniknięcie nieautoryzowanego dostępu do zasobów przechowywanych na serwerze.

1.3.8. Grupa zagrożeń Cross-Site Request Forgery (CSRF)

Grupa zagrożeń *Cross-Site Request Forgery (CSRF)* charakteryzuje się wykorzystaniem znajomości składni żądania, które przesyła przeglądarka do serwera aplikacji. Omawiane żądanie, przesłane zostaje przez atakującego w imieniu ofiary, co więcej atakujący może odpowiednio je zmodyfikować. Na uwagę zasługuje fakt, że spreparowanie adresu URL poprzez zmianę jego parametrów oraz podstępne przekazanie tego adresu użytkownikowi może być przyczyną przykrych konsekwencji dla tego użytkownika.

Na szczególną uwagę zasługuje fakt, że odpowiednio skonstruowany adres URL, można również umieścić w treści strony internetowej, z której korzysta atakowany użytkownik. Zostanie wówczas wykonane przesłanie żądania bez konieczności interakcji z tym użytkownikiem, który może być nieświadomy zagrożenia, z którym ma do czynienia.

Warto również podkreślić, że istnieje możliwość przekazania złośliwego adresu URL za pomocą ataku XSS. Umieszczenie takiego adresu w aktywnej treści strony internetowej np. wykorzystując *javascript* pozwala na automatyczne przesłanie żądania do serwera przy pierwszym odwołaniu do spreparowanego portalu.

Wynik zamierzonego działania, wykorzystującego atak z grupy CSRF, może zaistnieć w przypadku, gdy nieświadomy użytkownik, doprowadzi np. do usunięcia swojego konta użytkownika z danego portalu internetowego. Co bardzo istotne, stopień ryzyka jest znacznie podwyższony w sytuacji gdy, użytkownik korzystający z przeglądarki internetowej jest w danej chwili zalogowany do portalu, do którego atakujący przygotował spreparowany adres URL. W konsekwencji, takie działanie

może pozbawić użytkownika danych przechowywanych w ramach serwisu, które mają dla niego ważne znaczenie.

Jedną z metod zabezpieczenia aplikacji internetowej przed atakami z grupy CSRF jest wykorzystanie jednokrotnie używanego żetonu (ang. *token*), dla każdego żądania przesyłanego za pomocą protokołu HTTP. Taki żeton powinien być unikalny dla każdej sesji użytkownika. Zaleca się umieścić omawiany żeton w ukrytym polu aplikacji. Pozwoli to na przesłanie jego zawartości w ramach żądania HTTP, jednocześnie unikając dołączenia jej do adresu URL. Warto wspomnieć, że wymaganie ponownego uwierzytelnienia użytkownika, bądź wykorzystanie mechanizmu np. CAPTCHA (ang. *Completely Automated Public Turing test to tell Computers and Humans Apart*) również pozwala na poprawę bezpieczeństwa aplikacji internetowej i zabezpieczenia jej przed atakami z grupy CSRF.

1.3.9. Grupa zagrożeń Using Components with Known Vulnerabilities

Grupa zagrożeń o nazwie *Using Components with Known Vulnerabilities*, charakteryzuje się wykorzystywaniem podatności systemu informatycznego, wynikającej z budowy tego systemu w oparciu o moduły bądź usługi, w których wykryte zostały luki w systemie zabezpieczeń i są one powszechnie znane. W publikacji serwisu OWASP pt. „OWASP Top 10 for 2010" grupa ta stanowiła zbiór nazwany Security Misconfiguration. Należy podkreślić, że w omawianym dokumencie opublikowanym w 2013 r. pt. „OWASP Top 10 for 2013" zagrożenia tego rodzaju stanowią oddzielną grupę.

Co bardzo istotne, bezpieczeństwo systemu informatycznego uwarunkowane jest bezpieczeństwem poszczególnych jego elementów, składających się na całość tego systemu. W przypadku świadomego wykorzystania modułów bądź też usług, podatnych na pewnego rodzaju ataki, znacznie zmniejszony zostaje poziom zabezpieczeń systemu informatycznego.

Na szczególną uwagę zasługuje fakt, że nie wszystkie wykryte podatności składowych części systemu są publikowane w sposób, który pozwoli je łatwo identyfikować. W wielu przypadkach, nie można jednoznacznie stwierdzić, które wersje komponentów są bezpieczne, a które są podatne na różnego rodzaju ataki.

W wyniku budowy systemu opartego o moduły, bądź usługi posiadające błędnie zaimplementowany system zabezpieczeń, istnieje duże ryzyko przeprowadzenia ataku, który prowadzi do nieautoryzowanego dostępu do przechowywanych danych, bądź też przejęcia kontroli nad całym systemem informatycznym.

Omawianie metod zabezpieczenia aplikacji internetowej przed zagrożeniami należącymi do omawianej grupy, można rozpocząć od stwierdzenia, że w przypadku wykrycia podatności danego komponentu na różnego rodzaju ataki, nie są tworzone żadne poprawki zabezpieczające ten komponent. W wielu przypadkach, taki komponent zostaje poprawiony dopiero w momencie opublikowania jego nowszej wersji. W związku z powyższym, bardzo istotny wpływ na bezpieczeństwo aplikacji internetowych mają regularne aktualizacje wykorzystywanych modułów czy komponentów całego systemu informatycznego.

1.3.10. Grupa zagrożeń Unvalidated Redirects and Forwards

Ostatnią grupą zagrożeń, wymienionych w publikacji pt. „OWASP Top 10 for 2013" jest grupa nazwana *Unvalidated Redirects and Forwards*. Główną cechą, charakteryzującą zagrożenia należące do wspomnianej grupy, jest wykorzystywanie mechanizmów URL Redirect oraz Control Forward.

URL Redirect stanowi część składową protokołu HTTP, a jego zasada działania pozwala na informowanie przeglądarki internetowej o fakcie, że zasób do którego się odnosi w danej chwili znajduje się w innym miejscu. Efektem tego działania, jest zmiana adresu URL w pasku adresu przeglądarki na właściwy dla zasobu, do którego nastąpiło odwołanie.

Mechanizm Control Forward jest wewnętrzną operacją konkretnej aplikacji internetowej. Przeglądarka nie jest informowana o adresie zasobu, do którego w danej chwili odwołuje się użytkownik. Warto zwrócić uwagę na fakt, że adres URL w pasku adresu przeglądarki pozostaje niezmienny w przypadku korzystania z tego samego portalu. W zależności od praw dostępu do zasobów portalu, które posiada użytkownik z niego korzystający, wyświetlona strona wynikowa może się różnić, choć adres URL pozostanie ten sam.

W przypadku aplikacji korzystającej z jednego z wyżej opisanych mechanizmów, istnieje ryzyko wystąpienia podatności na atak wynikające z niewłaściwego zaprojektowania tej aplikacji. Przyczyną może być wykorzystywanie do określenia celu przekierowania danych podanych bezpośrednio przez przeglądarkę internetową użytkownika. W sytuacji braku, bądź błędnej implementacji odpowiednich metod walidacji przekazywanych parametrów, istnieje wysokie ryzyko wprowadzenia przez atakującego spreparowanych parametrów przekierowania w taki sposób, by spowodować wykonanie zupełnie innego działania niż przewidziane przez twórcę aplikacji. Warto wspomnieć, że może to prowadzić do nieautoryzowanego dostępu przez osobę nieupoważnioną do poufnych danych użytkownika.

Bezpieczeństwo aplikacji internetowej można poprawić poprzez zaprojektowanie tej aplikacji w taki sposób, aby nie wykorzystywała ona mechanizmu URL Redirect oraz Control Forward. W przypadku konieczności wykorzystania jednego z wyżej wymienionych mechanizmów należy zadbać o to, aby aplikacja w trakcie generowania adresu docelowego URL bądź jego fragmentu, nie używała danych przekazywanych przez przeglądarkę internetową. Jeśli dane te są niezbędne do poprawnego działania aplikacji, należy zaimplementować mechanizm pozwalający na weryfikację danych wprowadzanych przez użytkownika oraz mechanizm sprawdzający uprawnienia tego użytkownika dotyczące dostępu do części serwisu, do której zostanie on przekierowany.

Podsumowując powyższe rozważania na temat aplikacji internetowych oraz zagrożeń, na które mogą być podatne należy podkreślić jak ważny jest proces zabezpieczania omawianych aplikacji. W związku z ich dużą popularnością wynikającą przede wszystkim z mobilności, którą się charakteryzują oraz atrakcyjnością danych, do których dają dostęp, coraz częściej stają się celem ataków przeprowadzanych np. przez hakerów. Skutkiem takich działań jest nieautoryzowany dostęp do wrażliwych danych użytkowników, który może doprowadzić do modyfikacji bądź usunięcia tych danych, co przekłada się na poważne konsekwencje, np. finansowe. W związku z tym należy zwrócić szczególną uwagę na bezpieczeństwo tych aplikacji oraz na metody ich zabezpieczeń.

Rozdział 2

Opis funkcji filtra aplikacyjnego w zakresie transmisji WWW realizowanych przez Imperva SecureSphere

2.1. Firma Imperva i oferowane przez nią produkty

Zabezpieczanie aplikacji internetowych przed rosnącą liczbą przeprowadzanych ataków na te aplikacje wymaga zaangażowania, czujności oraz badań i przede wszystkim bezkompromisowej niezawodności. Głównym celem firm specjalizujących się w wytwarzaniu produktów poprawiających zabezpieczenia w sieci Internet jest umożliwienie przedsiębiorcom jak i użytkownikom indywidualnym swobodnego oraz bezpiecznego korzystania z funkcji oferowanych przez aplikacje webowe.

Jedną z takich firm jest Imperva, światowy lider w dziedzinie rozwiązań ochrony danych oraz egzekwowania reguł bezpieczeństwa w Data Center. Omawiana firma została założona w 2000 r. w USA. Jej współzałożycielem jest Shlomo Kramer, będący współtwórcą sukcesu firmy Check Point Software Technologies. Zgodnie z informacją prasową pt. „*Imperva Advances Protection Against Data Breaches With the Release of SecureSphere 10.5*" [3], opublikowaną w dniu 28 kwietnia 2014 r., firma Imperva posiada ponad 3000 klientów w ponad 75 krajach. Korzystają oni z produktu oferowanego przez firmę Imperva – SecureSphere. Imperva w swojej ofercie posiada m.in. mechanizmy gwarantujące wysoki poziom ochrony serwerów Web, a także serwerów aplikacyjnych przed różnego rodzaju atakami. Warto wskazać, że firma ta oferuje również rozwiązania do ochrony, monitorowania oraz wykonywania audytów baz danych największych producentów, takich jak: Microsoft, Oracle, Sybase oraz IBM. Szczególnie istotne jest, że proces wdrożenia rozwiązań firmy Imperva do istniejącej infrastruktury sieciowej, nie niesie ze sobą konieczności jej reorganizacji, co tym samym zapobiega generowaniu dodatkowych kosztów, oraz znacznie przyspiesza, a także ułatwia omawiany proces [4].

Produkty oferowane przez firmę Imperva można podzielić na cztery główne kategorie w zależności od ich przeznaczenia [3]:

- Web Application Security,
- File Security,

- Database Security,
- SharePoint Security.

2.2. Charakterystyka produktów firmy Imperva

W ramach kategorii *Web Application Security* wyróżnić można moduły takie jak: *Web Application Firewall* czy *ThreatRadar.* Ich głównym przeznaczeniem jest ochrona aplikacji internetowej przed różnego rodzaju atakami wykorzystującymi np. podatność atakowanej aplikacji bądź niedoskonałości aktualnego zabezpieczenia danego systemu informatycznego.

Kategoria *File Security* to przede wszystkim narzędzia pozwalające na zabezpieczenie wszelkiego rodzaju danych przechowywanych w postaci plików. Wykorzystanie tych narzędzi ma na celu zapobieganie kradzieży przechowywanych informacji. W tej kategorii wyróżnić można moduły takie, jak: *File Activity Monitor*, *File Firewall*, czy *Directory Services Monitor*.

Kolejną z wymienionych kategorii jest *Database Security.* W przypadku dużych firm, jak również małych przedsiębiorstw, znaczna część informacji wykorzystywanych w ich pracy codziennej, przechowywana jest w postaci bazy danych. Istotne jest, by gromadzone i przetwarzane dane były ze sobą zgodne, a także skutecznie chronione. Według firmy Imperva, bezpieczeństwo danych przechowywanych w taki sposób zapewniają produkty z omawianej kategorii, do których zakwalifikować możemy np. *Database Activity Monitor* czy *Database Firewall*.

Kategoria *SharePoint Security* to zbiór narzędzi przeznaczonych do zabezpieczenia platformy aplikacji internetowych stworzonej i rozwijanej przez firmę Microsoft. Platforma ta zaprojektowana została z myślą o złożonych aplikacjach webowych wspierających zarządzanie, publikacje oraz manipulację informacjami pomiędzy użytkownikami np. sieci korporacyjnej. Platforma *SharePoint* zapewnia łatwy dostęp do krytycznych danych biznesowych korporacji z niej korzystającej, za pośrednictwem sieci intranet jak również extranet. W związku z powyższym, bezpieczeństwo omawianej platformy jest szczególnie istotne. Zagwarantować je ma produkt firmy Imperva o nazwie *SecureSphere for SharePoint*.

2.3. Charakterystyka produktów z grupy Web Application Security

W ramach niniejszej pracy na szczególną uwagę zasługują produkty sklasyfikowane w grupie *Web Application Security*. Gwarantują one bezpieczeństwo aplikacji internetowych przed cyberatakami. Produkt *SecureSphere* jest stale dostosowywany do zmieniających się zagrożeń, przez co zmniejsza ryzyko dostępu do danych przez niepowołane osoby. Omawiany produkt pozwala m.in.:

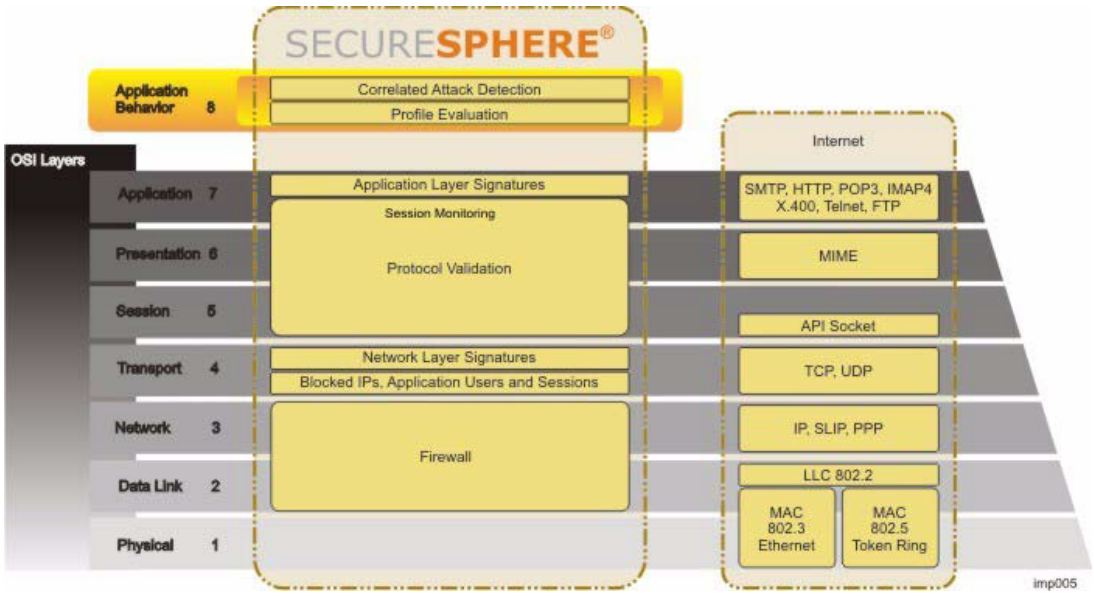
1. tworzyć wzorzec poprawnego korzystania z aplikacji internetowej,
2. zgłaszać bądź blokować żądania dostępu:
    - odbiegające od normalnego korzystania z danych aplikacji,
    - próbujące wykorzystać znane oraz nieznane luki systemu,
    - pochodzące ze szkodliwych źródeł,
    - naruszające zasady korporacyjne,
    - będące częścią ataku wielostopniowego,
3. aktualizować ochronę sieci zgodnie z wynikami badań prowadzonych nad aktualnymi zagrożeniami.

Narzędzie *SecureSphere* należące do grupy rozwiązań *Web Application Security* składa się z dwóch głównych elementów. Pierwszym z nich jest *Web Application Firewall.* Jako wiodące narzędzie zapewnia ono automatyczną ochronę przed znanymi metodami ataku na aplikację internetową, w tym SQL Injection, XSS czy CSRF. Omawiane narzędzie gwarantuje automatyczne stosowanie aktualnych zasad i sygnatur pochodzących z *Imperva ADC* (ang. *Application Defense Center*), co pozwala identyfikować ewentualne ataki oraz w porę im zapobiegać. Warto podkreślić, że narzędzie *Web Application Firewall* „potrafi poznać" strukturę aplikacji webowej tzn. jej adresy URL, katalogi, parametry, metody wykorzystywane w celu wywołania konkretnych adresów URL, a także pliki *cookie*, które są zwykle używane w ramach aktywnej sesji użytkownika. Warto również zauważyć, że narzędzie to jednocześnie „uczy się" oczekiwanego zachowania użytkownika w stosunku do wszystkich wyżej wymienionych elementów, co pozwala na automatyczne stworzenie oraz aktualizację modelu tej aplikacji internetowej.

Drugim z narzędzi jest *ThreatRadar*, będący dodatkowym modułem poprawiającym poziom zabezpieczeń oferowany przez *Web Application Firewall*.

Usprawnia on m.in. ochronę aplikacji webowej przed zautomatyzowanymi atakami na dużą skalę. Zapewnia także ochronę w czasie rzeczywistym omawianej aplikacji przed atakami pochodzącymi ze znanych źródeł takich jak szkodliwe adresy IP czy adresy URL wyłudzające poufne dane. Co bardzo istotne, poprzez przekazywanie źródła prowadzonego ataku do narzędzia *Web Application Firewall, ThreatRadar* umożliwia szybkie oraz skuteczne blokowanie szkodliwych użytkowników zanim zostanie rozpoczęte przeprowadzanie ataku na aplikację internetową.

System zabezpieczeń aplikacji internetowej dostarczany poprzez narzędzie SecureSphere oparty jest o 7-mio warstwowy model OSI. Zapora sieciowa pracuje w ramach 2, 3 oraz 4 warstwy wspomnianego modelu, walidacja protokołu w warstwie 5, 6 oraz 7, natomiast sygnatury warstwy aplikacji wyłącznie w warstwie 7. Istotną cechą produktu SecureSphere, jest wprowadzenie przez firmę Imperva dodatkowej warstwy 8 nie będącej częścią modelu OSI. W ramach tej warstwy odbywa się m.in. wykrywanie skorelowanych ataków (rys. 1).



Rys. 1. SecureSphere Web Application Firewall w modelu OSI [5]

Model zabezpieczeń oferowanych przez produkt *SecureSphere* można również przedstawić w następujący sposób (rys. 2).



Rys. 2. Warstwy ochrony SecureSphere Web Application Firewall [5]

Na rysunku nr 2 przedstawiającym warstwy ochrony zapewniane przez *SecureSphere Web Application Firewall* można wyróżnić następujące elementy:

- Protocol Validation – mechanizm zapobiegający naruszeniom protokołu HTTP poprzez atak wykorzystujący ten protokół, np. próbie przepełnienia bufora poprzez wyjątkowo duży nagłówek żądania HTTP.
- Attack Signatures – mechanizm określający znane aplikacje, platformy oraz ataki sieciowe. SecureSphere posiada bazę ponad 6500 sygnatur, które są co tydzień aktualizowane przez ekspertów z *ADC*.
- Data Leak Prevention – mechanizm wykrywający poufne dane, takie jak numery kart kredytowych lub informacje osobowe wyświetlane na stronie internetowej. Podane zachowanie aplikacji internetowej może oznaczać wyciek danych. SecureSphere identyfikuje te dane, co pozwala administratorowi systemu informatycznego stwierdzić, czy są one poprawnie wykorzystane.
- Application Profile – mechanizm porównujący rzeczywiste wykorzystanie aplikacji internetowej w danej chwili, z oczekiwanym wykorzystaniem wynikającym ze stworzonego modelu aplikacji przez narzędzie *SecureSphere* w celu identyfikacji podejrzanych zdarzeń, bądź podejrzanego zachowania użytkownika korzystającego z tej aplikacji.
- Web Worm Detection – mechanizm wykorzystujący zaawansowane algorytmy w celu wykrycia potencjalnego ataku na aplikację internetową przy użyciu nieznanej do tej pory podatności tej aplikacji.

- Correlation Engine – korelacja informacji o pojawiającym się zdarzeniu umożliwiająca podjęcie akcji w zależności od zdefiniowanych reguł korelacji z wykorzystaniem CAV (ang. *Correlated Attack Validation*).

Na szczególną uwagę zasługuje fakt, jak ważną rolę w procesie zabezpieczania aplikacji internetowej przez narzędzie SecureSphere odgrywa zespół ekspertów *Imperva ADC*. Badania przeprowadzane nad nowo wykrytymi zagrożeniami opierają się na wielu źródłach i skupiają się na następujących zagadnieniach:

- analizie zachowania aplikacji działających w oparciu o wiele stacji roboczych, takich jak SAP czy ORACLE EBusinessSuite, jak również aplikacji wykorzystujących PHP czy AJAX,
- zbieraniu informacji dotyczących podatności, wykrytych przez inne firmy z branży, a także informacji o poprawkach wydanych przez producentów poszczególnych produktów,
- zapewnieniu narzędziu SecureSphere najnowszych zabezpieczeń, w tym aktualizacji sygnatur, profili audytowych, a także raportów.

Integracja produktu *SecureSphere* z wynikami opracowywanymi przez zespół *Imperva ADC* umożliwia stałe zabezpieczenie systemu informatycznego przed nowymi zagrożeniami.

Bardzo istotnym modułem zaimplementowanym w produkcie *SecureSphere* jest moduł nazwany *Dynaming Profiling*. Zapewnia on unikalną warstwę zabezpieczeń, której działanie opiera się na profilowaniu dynamicznym. Warstwa ta umożliwia wykrywanie i ochronę przed zagrożeniami, które są specyficzne dla ataku aplikacyjnego. Ataki tego typu nie mogą zostać wykryte za pomocą istniejących sygnatur czy też mechanizmów zapory sieciowej, ponieważ wymagają fazy uczenia, na podstawie której produkt zabezpieczający rozpoznaje strukturę każdego z chronionych adresów URL. *Dynaming profiling* umożliwia automatyczne generowanie niezbędnych profili, a następnie wykorzystuje je do wykrywania anomalii bądź naruszeń bezpieczeństwa systemu, po czym blokuje atak odwołujący się do kodu aplikacji internetowej. Pierwsza faza działania omawianego modułu polega na nauce struktury sposobu wykorzystywania aplikacji internetowej, poprzez gruntow-

ną analizę jej struktury. Po odpowiednim okresie uczenia następuje przejście do fazy drugiej, poprzez uaktywnienie trybu *protect,* w którym to generowane są zdarzenia wykorzystania aplikacji internetowej naruszające zasady opracowane w trakcie trwania fazy pierwszej, czyli tzw. okresie nauki. Wszystkie wyżej wymienione czynności odbywają się w sposób całkowicie transparentny dla użytkownika, co znacznie przyspiesza proces początkowej konfiguracji systemu zabezpieczeń oraz pozwala uniknąć występowaniu wielu fałszywych alarmów, co jest typowe w chwili wdrażania systemu zabezpieczeń. Warto nadmienić, że profile dynamiczne wykorzystywane przez narzędzie *SecureSphere* mogą być ręcznie zmieniane, zaś możliwość dodawania bądź usuwania zawartych w nich informacji, zapewnia precyzyjną konfigurację systemu zabezpieczeń.

Kolejnym z modułów oferowanych przez producenta Imperva w ramach systemu zabezpieczeń *SecureSphere* jest moduł nazwany *Assessment Server.* Główną cechą omawianego modułu jest umożliwienie integracji narzędzia *SecureSphere* ze skanerami podatności takimi, jak: IBM AppScan, HP WebInspect, NTObjectives, Cenzic oraz WhiteHat, wytwarzanymi przez innych producentów. Wyniki przeprowadzonego skanowania aplikacji internetowej pod kątem jej podatności na różnego typu ataki, umieszczone zostają w bazie danych kolejnego z modułów – *Vulnerability Workbench*. Produkt SecureSphere zintegrowany jest z CVSS (ang. *Common Vulnerabilities Scoring System*), prowadzonym przez Narodowy Instytut Standaryzacji i Technologii (ang. *National Institute of Standards and Technology*), który analizując zagrożenia wynikające z podatności aplikacji internetowych ocenia je w skali od 0 do 10, bazując w swojej ocenie na czynnikach takich jak łatwość przeprowadzenia tego ataku oraz skutki wykorzystania danej podatności przez atakującego.

Co bardzo istotne, aby wspomóc zarządzanie wykrywaniem podatności aplikacji internetowej w oparciu o szacowanie, system zabezpieczeń SecureSphere posiada zaimplementowany moduł o nazwie *Vulnerability Workbench*. Moduł ten umożliwia przechowywanie wszelkich wykrytych, w trakcie przeprowadzonego skanowania, podatności omawianej aplikacji. Omawiane narzędzie pozwala użytkownikowi zarządzającemu systemem zabezpieczeń na przypisywanie wykrytym

podatnościom m.in. takich cech, jak status czy priorytet. Podczas gdy niektóre z wykrytych luk wymagają manualnego podjęcia czynności związanych z ich zabezpieczeniem, w przypadku pozostałych, system zabezpieczeń może zablokować ich komunikację w celu poprawy bezpieczeństwa całego systemu informatycznego.

Kolejną funkcją realizowaną przez narzędzie *SecureSphere* jest mechanizm wykrywania botów oraz wszelkiego rodzaju skryptów automatycznie pobierających informacje ze strony WWW. Omawiany mechanizm działa na zasadzie przesyłania niewidocznego dla użytkownika aplikacji webowej JavaScript. Na podstawie reakcji wykonanej po stronie klienta, mechanizm jest w stanie wykryć, czy klient jest automatem czy też nie. W przypadku, gdy przeglądarka znajdująca się po stronie klienta, wykona przesłany skrypt zapisując przy tym plik *cookie,* wówczas oznacza to, że klientem nie jest automat. W przeciwnym razie mechanizm zabezpieczający, rozpozna klienta jako skrypt, bądź bot.

Na uwagę zasługuje również kolejna z funkcji oferowanych przez produkt *SecureSphere*, a mianowicie tzw. *Universal User Tracking*. Funkcja ta, umożliwia identyfikowanie nazwy użytkownika korzystającego z zasobów oferowanych przez aplikację webową, która jest przesyłana w zapytaniach odwołujących się do tej aplikacji. Pozwala to określić na podstawie generowanych logów zdarzeń, dla jakiego użytkownika aplikacji, wykonała ona zapytanie do bazy danych. *Universal User Tracking* umożliwia korelację nazw użytkowników, będących w danej chwili zalogowanych w aplikacji internetowej wraz z dokonywanymi przez tę aplikację transakcjami w bazie danych. Bardzo istotne jest, że na podstawie analizy ruchu lub wykorzystując odpowiednich agentów bezpośrednio na bazie danych, istnieje możliwość audytu działalności użytkowników oraz administratorów. Mechanizm ten jest niezależny od bazy danych, w związku z czym nie obciąża jej dodatkowymi zadaniami.

Rozdział 3

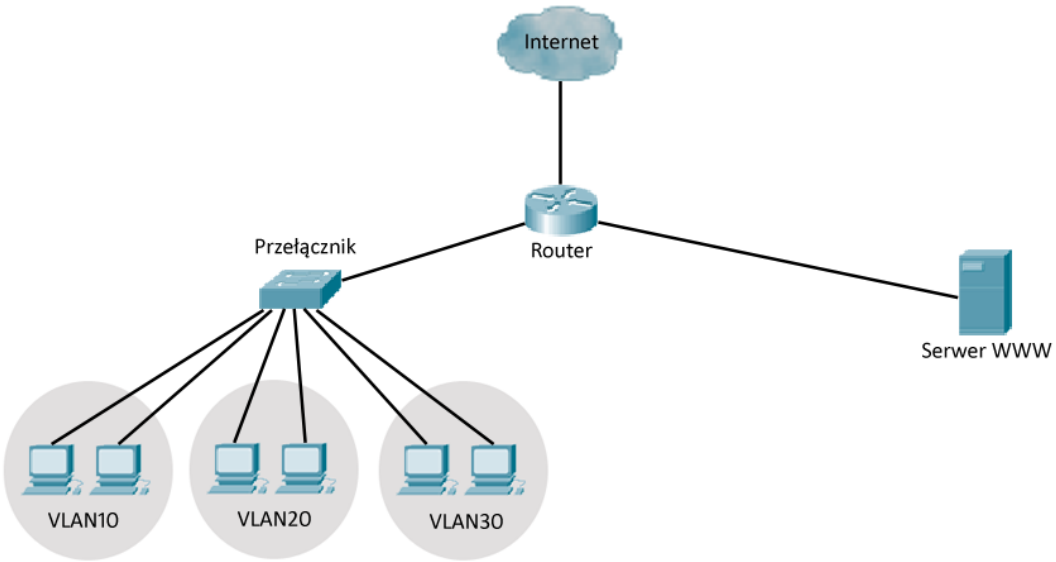
Opracowanie wymagań na system służący do ochrony aplikacji internetowej

3.1. Analiza istniejącej infrastruktury teleinformatycznej

Podstawę rozważań na temat wymagań dla implementowanego systemu zabezpieczeń poprzedziła analiza obecnej infrastruktury sieciowej firmy zgłaszającej zamówienie na tego typu rozwiązania. Pozwoliło to na ukierunkowanie działań niezbędnych do wdrożenia omawianego systemu.

W niniejszym projekcie przyjęto, że w siedzibie firmy występującej w roli zamawiającego, istnieje sieć komputerowa, która została zaprojektowana z myślą o udostępnieniu jej użytkownikom podstawowych usług sieciowych, takich jak dostęp do Internetu oraz wymiana plików w ramach sieci lokalnej.

Zarząd firmy podjął decyzję o rozwoju oferty usług realizowanych przez wspomniane przedsiębiorstwo. W związku z tym, potencjalnym klientom firmy zostanie udostępniona w ramach sieci Internet aplikacja internetowa, pozwalająca na przegląd oferowanego asortymentu, a także możliwość składania zamówień drogą elektroniczną. Szczególnego podkreślenia wymaga fakt, że omawiana aplikacja zostanie zainstalowana na serwerze WWW, który został już podłączony do istniejącej infrastruktury sieciowej siedziby firmy.



Rys. 3. Topologia istniejącej sieci teleinformatycznej

Na rysunku 3 przedstawiono dotychczas funkcjonującą infrastrukturę teleinformatyczną w siedzibie zamawiającego. Zostały na nim wyróżnione 3 istniejące sieci VLAN (*ang. Virtual Local Area Network*) tj. VLAN10, VLAN20, VLAN30 oraz połączenie pomiędzy serwerem WWW przeznaczonym na potrzeby instalacji aplikacji internetowej a siecią Internet.

3.2. Cel inwestycji

Celem inwestycji, określonym przez zarząd zamawiającego, jest dotarcie do nowych klientów, a także skrócenie czasu składania i realizacji zamówień poprzez zautomatyzowanie tych czynności proceduralnych. W związku z tym, szczególną uwagę zwrócono na zagwarantowanie bezpieczeństwa wszelkich danych wykorzystywanych przez udostępnioną aplikację webową. Ma to szczególne znaczenie zważywszy na fakt, że, wśród nich będą się znajdowały takie informacje, jak:

- podstawowe dane osobowe klientów,
- historia zrealizowanych transakcji,
- zbiór podstawowych informacji o oferowanym asortymencie.

  Wyciek bądź nieautoryzowana modyfikacja wymienionych danych, może mieć bardzo poważne wieloaspektowe następstwa, zarówno dla potencjalnych klientów firmy, jak i dla niej samej.

3.3. Wymagania funkcjonalne na projektowany system

Na podstawie analizy żądań zgłoszonych przez firmę zamawiającą wdrożenie systemu zabezpieczeń aplikacji webowej, wyodrębnione zostały następujące wymagania funkcjonalne:

- wykorzystanie możliwie jak najmniejszej liczby dodatkowych urządzeń sieciowych,
- zabezpieczenie aplikacji internetowej przede wszystkim przed atakami grupy *Injection i Cross-Site Scripting,*
- wdrożone zabezpieczenie aplikacji internetowej nie powinno mieć wpływu na prędkość transmisji pomiędzy urządzeniami pracowników firmy korzystających z sieci lokalnej,

- system zabezpieczeń aplikacji webowej nie może oddziaływać na prędkość działania tej aplikacji,
- możliwość dostosowywania systemu zabezpieczeń do nowo wykrytych rodzajów ataków,
- zagwarantowanie raportowania wszelkiej działalności użytkowników udostępnionej aplikacji, która nosi znamiona próby przeprowadzenia ataku,
- zabezpieczenie aplikacji pod kątem przeprowadzania potencjalnych ataków, które mogą być przyczyną wycieku bądź modyfikacji przechowywanych wrażliwych danych.

3.4. Wymagania niefunkcjonalne na projektowany system

Szczegółowe uzgodnienia dokonane z firmą zamawiającą projekt oraz implementację systemu zabezpieczeń pozwoliła także na określenie niezbędnych wymagań niefunkcjonalnych, które powinien spełniać przygotowany projekt. Wymagania dotyczące wdrożonego systemu zabezpieczeń sformułowano następująco:

- powinien być niezawodny w ramach określonych rodzajów ataków,
- powinien być dostępny przez cały czas, umożliwiając stałe filtrowanie ruchu sieciowego pomiędzy siecią Internet, a aplikacją internetową,
- powinien umożliwiać jego modernizację poprzez dodanie nowych funkcji systemu bez konieczności rozbudowywania infrastruktury sieci teleinformatycznej o nowe urządzenia sieciowe.

Rozdział 4

Opracowanie projektu systemu

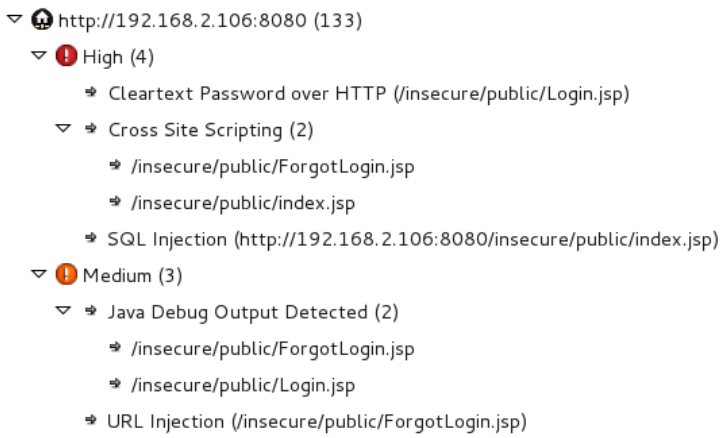
4.1. Wstępne testy penetracyjne zabezpieczanej aplikacji internetowej

Przed przystąpieniem do opracowania projektu systemu zabezpieczeń aplikacji internetowej, która zostanie wdrożona w firmie będącej stroną zamawiającą, należało przeprowadzić testy penetracyjne oraz serię próbnych ataków na jedną z ogólnodostępnych aplikacji webowych. Wykorzystana w tym przypadku aplikacja o nazwie *Insecure Web Application*, została przygotowana przez organizację charytatywną OWASP zajmującą się m.in. bezpieczeństwem oprogramowania. Aplikacja ta pozwala na testowanie metod ataku, a także skuteczności zaimplementowanych zabezpieczeń.

Omawiana aplikacja powstała w technologii JSP (ang. *JavaServer Pages*). W celu implementacji jej podstawowych funkcji oraz zapewnienia funkcjonalności takiej jak logowanie użytkowników wykorzystano bazę danych SQL.

4.1.1. Badanie podatności aplikacji programem Vega

Celem wykrycia podatności zabezpieczanej aplikacji internetowej zostały wykonane testy penetracyjne przeprowadzone za pomocą aplikacji Vega, będącej jednym ze składników systemu Kali Linux w wersji 1.0.5. W aplikacji tej, należało określić adres sieciowy celu ataku, co pozwoliło rozpocząć skanowanie pod kątem podatności aplikacji webowej na ataki z grupy *injection* czy *XSS*. Raport skanowania przedstawiony został na rysunku 4.

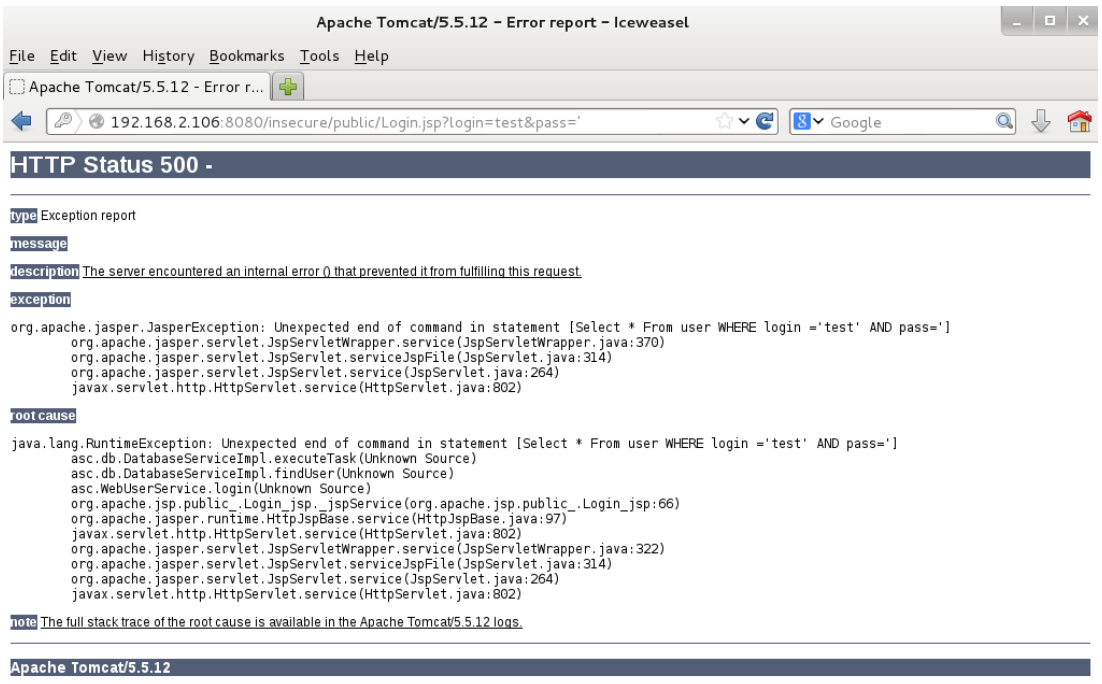


Rys. 4. Szczegóły raportu programu Vega

Na podstawie analizy otrzymanego raportu istnieje możliwość określenia metod ataku, na które podatna jest testowana aplikacja internetowa. W omawianym przypadku podatności, które mogą zostać wykorzystane w trakcie przeprowadzania ataku to *Cross Site Scripting (XSS)* oraz *SQL Injection.* Warto również podkreślić, że istotną podatnością testowanej aplikacji internetowej jest eksponowanie błędów występujących po stronie serwera tej aplikacji, co zostało przedstawione w raporcie programu Vega w pozycji *Java Debug Output Detected*.

4.1.2. Przeprowadzenie ataku z grupy Injection

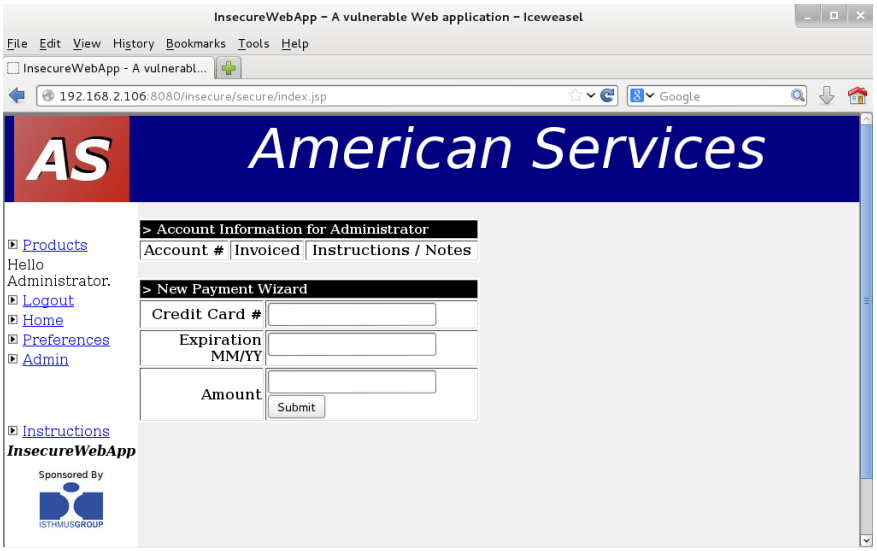
Próba przeprowadzenia ataku z grupy *injection* na zabezpieczaną aplikację webową polegała na wywołaniu błędu serwera w momencie logowania do tej aplikacji. Po wprowadzeniu loginu „*test*” oraz hasła „ ‘ ” nastąpiło przekazanie parametrów logowania w postaci jawnej za pomocą adresu URL do aplikacji, a następnie spowodowało wygenerowanie błędu serwera, który został przestawiony na rysunku 5.



Rys. 5. Wystąpienie błędu serwera aplikacji internetowej

Dla potrzeb przeprowadzanego ataku, istotny jest wiersz zawierający treść wykonywanego polecenia SQL. Polecenie to ma następującą postać: *Select * From*

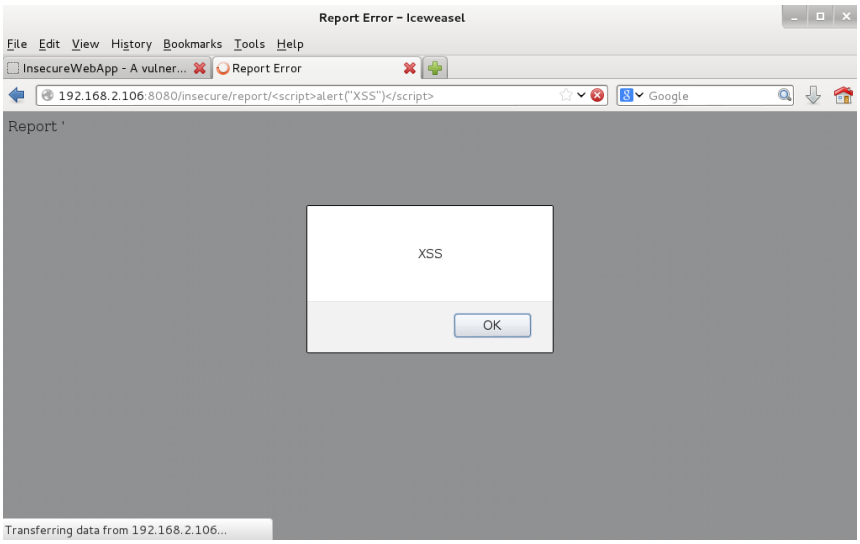
user WHERE login ='test' AND pass='. Na podstawie analizy tego polecenia przygotowany został login o następującej treści: *1' OR 1=1 OR '1'='1*, który po wprowadzeniu w oknie logowania użytkownika pozwolił na zalogowanie się do systemu z uprawnieniami zarejestrowanego użytkownika posiadającego najniższy numer identyfikacyjny w bazie danych. W tym przypadku jest to konto z uprawnieniami administratora (rys. 6).



Rys. 6. Nieautoryzowany dostęp do aplikacji internetowej

4.1.3. Przeprowadzenie ataku z grupy Cross-Site Scripting (XSS)

W trakcie testów podatności zabezpieczanej aplikacji internetowej przeprowadzony został również atak z grupy XSS. Atak ten polegał na takim spreparowaniu adresu URL, aby wykonany został złośliwy kod po stronie klienta aplikacji internetowej. Adres ten wyglądał następująco: *192.168.2.106:8080/insecure/report/<script> alert(„XSS")</script>* (rys. 7).



Rys. 7. Wynik działania spreparowanego adresu URL

Przeprowadzone ataki, wykorzystujące luki w zabezpieczeniach aplikacji internetowej, mogą być przyczyną nieautoryzowanego dostępu do zasobów tej aplikacji np. poprzez wykorzystanie ataku z grupy *SQL Injection*, bądź kradzieży danych zawartych w plikach *Cookie* zalogowanego użytkownika za pomocą ataku z grupy *XSS*. Niesie to ze sobą wiele konsekwencji i zagraża bezpieczeństwu zarówno danych przechowywanych na serwerze aplikacji webowej jak również jej użytkowników.

4.2. Projekt systemu zabezpieczeń aplikacji internetowej

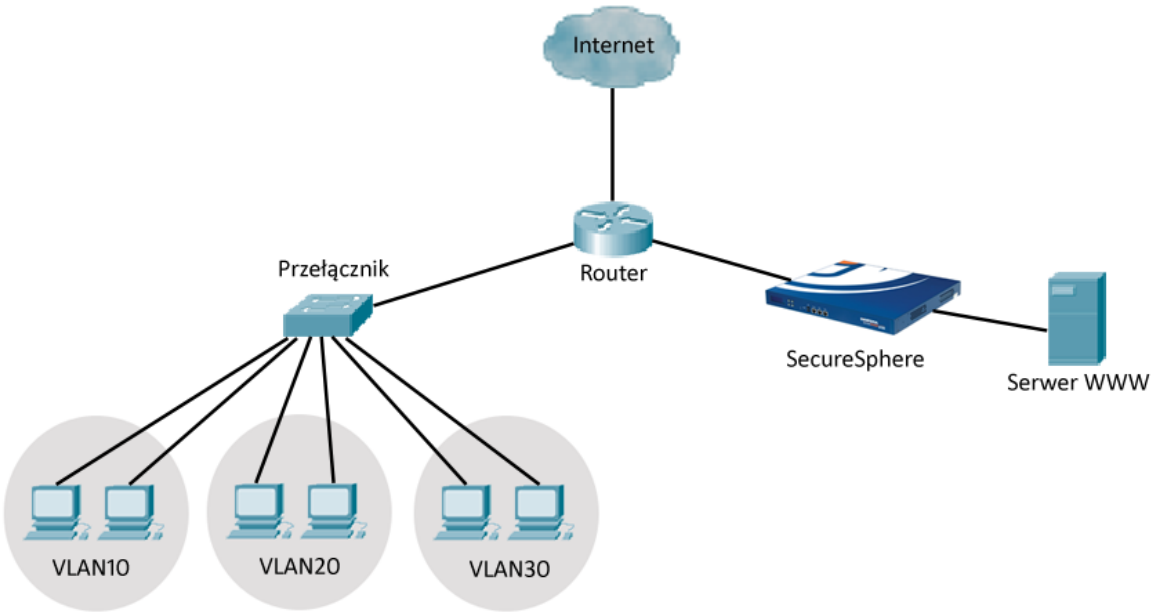
Projekt systemu zabezpieczeń aplikacji internetowej zakłada wykorzystanie rozwiązań dostarczanych przez firmę Imperva w ramach produktu SecureSphere. Składa się on z dwóch podstawowych elementów, które znacząco podnoszą poziom bezpieczeństwa aplikacji webowych. Głównym elementem oferowanym w ramach omawianego produktu jest *Web Application Firewall*, stanowiący podstawę implementowanego systemu zabezpieczeń, natomiast jego funkcjonalność jest uzupełniana za pośrednictwem drugiego z elementów jakim jest *ThreatRadar*.

W wyniku uwzględnienia wymagań zgłoszonych przez firmę zamawiającą, a także dokonanej analizy istniejącej infrastruktury sieciowej, opracowany został projekt systemu zabezpieczeń aplikacji internetowej wykorzystujący następujące cechy produktu SecureSphere:

- stosowanie aktualnych zasad i sygnatur pochodzących z *Imperva ADC*,

- weryfikowanie działań użytkownika w oparciu o posiadane sygnatury ataków,
- wykrywanie poufnych danych wyświetlanych na stronie internetowej celem identyfikacji poprawności ich wykorzystania,
- porównywanie rzeczywistego wykorzystania aplikacji z oczekiwanym wykorzystaniem określonym w ramach stworzonego modelu aplikacji,
- wykorzystywanie profili dynamicznych celem ochrony aplikacji webowej przed zagrożeniami specyficznymi dla ataku aplikacyjnego,
- raportowanie wszelkich zdarzeń takich jak występowanie wyjątków czy naruszeń zabezpieczeń systemu.

Uwzględniając wymagania niefunkcjonalne określone na podstawie żądań zgłoszonych przez firmę zamawiającą, model przedstawiający istniejącą infrastrukturą sieciową (rys. 8) został rozszerzony o omawiane narzędzie *SecureSphere*, które zostanie zaimplementowane w omawianą infrastrukturę pomiędzy routerem, a serwerem WWW celem filtrowania transmisji sieciowej.



Rys. 8. Projekt zabezpieczenia aplikacji internetowej z wykorzystaniem produktu SecureSphere

Produkt SecureSphere wspiera 3 tryby wdrożenia w istniejącą strukturę teleinformatyczną:

- Gateway w jednym z wymienionych trybów:
- transparent bridge,
- sniffing mode,
- reverse proxy,
- Management Server (MX),
- SecureSphere Operations Manager (SOM).

Wymienione tryby pracy dostępne są zarówno w wersji fizycznej jak i wersji wirtualnej urządzenia, co pozwala na skuteczne dopasowanie implementowanego produktu do posiadanego sprzętu teleinformatycznego oraz warunków w których zostanie wdrożony.

Na potrzeby realizowanego projektu systemu zabezpieczeń, planuje się wdrożenie rozwiązania SecureSphere w wersji wirtualnej z wykorzystaniem dwóch trybów pracy, tj. bramy (ang. *Gateway*) oraz serwera zarządzającego (ang. *Management Server*). Serwer zarządzający będzie pełnił funkcje administracyjne nad połączoną z nim bramą działającą w trybie odwrotnego proxy (ang. *reverse proxy*). Brama natomiast, będzie pełniła funkcję filtra sieciowego pomiędzy klientami firmy zamawiającej, korzystającymi z oferowanych usług internetowych, a aplikacją internetową zainstalowaną na serwerze WWW.

Przewidywany sposób wdrożenia produktu SecureSphere w istniejącą sieć teleinformatyczną, będzie składał się z trzech głównych kroków, realizowanych w następującej kolejności:

1. Konfiguracja maszyny wirtualnej działającej w trybie serwera zarządzającego.
2. Konfiguracja maszyny wirtualnej działającej w trybie bramy.
3. Konfiguracja produktu SecureSphere poprzez dostosowanie zasad bezpieczeństwa w celu zabezpieczenia aplikacji internetowej.

Kolejność wdrażania serwera zarządzającego oraz bramy jest istotna, ponieważ pozwoli na poprawną konfigurację połączenia pomiędzy dwoma instancjami maszyn wirtualnych zawierającymi narzędzie SecureSphere oraz na skuteczne administro-

wanie zasadami bezpieczeństwa w dalszej fazie implementacji produktu. Środowiskiem, w którym osadzone zostaną wykorzystywane maszyny wirtualne będzie program VMware Workstation.

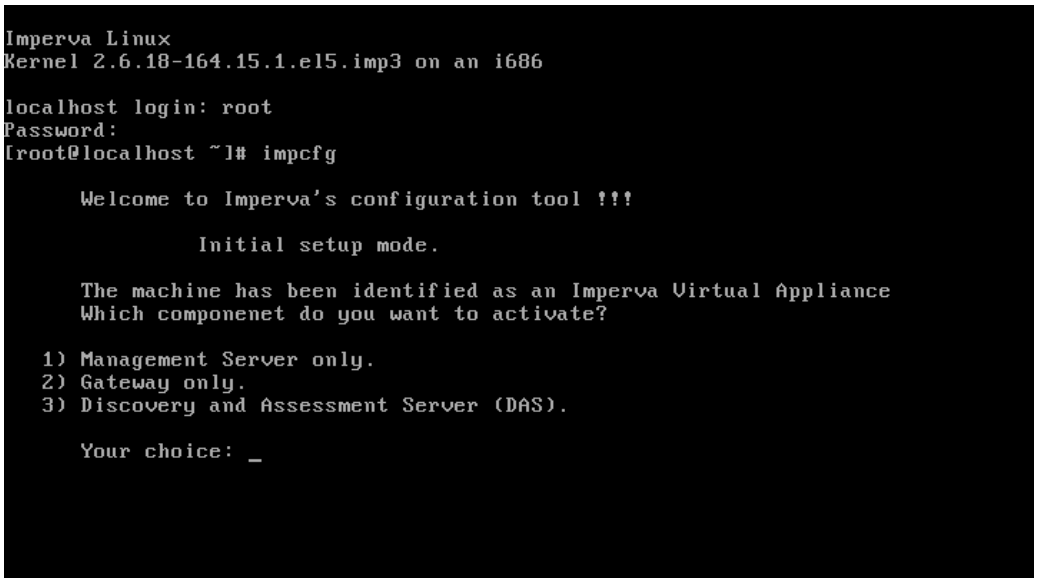
Rozdział 5

Implementacja systemu

5.1. Konfiguracja serwera zarządzającego (MX)

Konfigurację maszyny wirtualnej, która będzie pełniła funkcję serwera zarządzającego należy rozpocząć od zaimportowania obrazu tej maszyny do programu VMware, w którym przed przystąpieniem do uruchomienia maszyny, niezbędne jest odpowiednie skonfigurowanie interfejsów sieciowych i przypisanie tych interfejsów do konfigurowanej maszyny. Do poprawnej pracy serwera zarządzającego wymagany jest interfejs zarządzający, który pozwala na komunikację maszyny z drugą instancją SecureSphere pełniącą rolę bramy. Opcjonalnie można skonfigurować interfejs lokalny, który umożliwi komunikację urządzenia SecureSphere z siecią lokalną.

Po przypisaniu interfejsów sieciowych do maszyny wirtualnej, należy ją uruchomić, zalogować się do systemu, a następnie wprowadzić w konsoli polecenie „*impcfg*", które spowoduje rozpoczęcie pracy kreatora konfiguracyjnego produktu SecureSphere (rys. 9).



Rys. 9. Ekran powitalny kreatora konfiguracji produktu SecureSphere

Kreator konfiguracji produktu SecureSphere umożliwia jego konfigurację w trybie serwera zarządzającego po wybraniu pierwszej z dostępnych opcji tj. „*Management Server only*". W kolejnych krokach kreatora możliwe jest wprowadzenie adresów IP

dla konfigurowanych interfejsów sieciowych, adresu domyślnej bramy sieciowej, adresu serwera DNS, hasła dostępu do systemu (*root*, *secure*, *bootloader*), hasła dostępowego bazy danych, nazwy serwera, a także strefy czasowej.

Poprawne wykonanie konfiguracji serwera zarządzającego umożliwia jego pierwsze uruchomienie. Dostęp do skonfigurowanego serwera można uzyskać m.in. za pośrednictwem przeglądarki internetowej łącząc się z następującym adresem URL: *https://adres_serwera:8083,* bądź poprzez polecenie *SSH adres_serwera –l login* wydane w konsoli.

5.2. Konfiguracja bramy

Krokiem kolejnym, po uruchomieniu serwera zarządzającego jest przystąpienie do konfiguracji drugiej instancji maszyny wirtualnej SecureSphere, która zostanie wdrożona w trybie bramy. Instalacja omawianej maszyny wirtualnej przebiega w sposób zbliżony do instalacji maszyny pełniącej rolę serwera zarządzającego. Pierwszą czynnością, którą należy wykonać jest zaimportowanie obrazu tej maszyny do programu VMware, a następnie konfiguracja jej interfejsów sieciowych. Do poprawnej pracy maszyny wirtualnej w trybie bramy niezbędne jest poprawne ustawienie interfejsu zarządzającego umożliwiającego komunikację z serwerem zarządzającym, dwóch interfejsów pomiędzy którymi utworzone zostanie połączenie, a także interfejsu lokalnego pozwalającego na komunikację bramy z siecią lokalną.

Po wykonaniu wstępnego ustawienia interfejsów sieciowych maszyny wirtualnej należy ją uruchomić, a następnie zalogować się do systemu. Wpisanie polecenia „*impcfg*” powoduje uruchomienie kreatora wstępnej konfiguracji produktu SecureSphere (rys. 9). W celu przygotowania środowiska do pracy w trybie bramy należy wybrać opcję „*Gateway only*” a następnie zatwierdzić wybór. Podczas pracy uruchomionego kreatora konfiguracji produktu SecureSphere, istnieje możliwość ustawienia parametrów maszyny niezbędnych do jej poprawnej pracy oraz komunikacji z serwerem zarządzającym, takich jak adresy sieciowe zainstalowanych interfejsów sieciowych czy adres serwera zarządzającego. Warto podkreślić, że brama może zostać wdrożona w jednym z następujących trybów:

- Sniffing mode – w trybie tym brama nie pośredniczy w ruchu sieciowym pomiędzy klientem i serwerem, natomiast ruch sieciowy jest przesyłany do niej w postaci kopii, a następnie jest analizowany przez tę bramę.
- Transparent bridge – w trybie tym brama pełni funkcję mostu sieciowego pomiędzy siecią, w której znajduje się klient, a siecią w której umieszczony jest serwer. Ruch sieciowy pomiędzy klientem i serwerem jest przesyłany oraz analizowany przez ten most, jednakże jest on niewidoczny z punktu widzenia klienta jak i serwera.
- Reverse proxy – istotną cechą bramy pracującej w tym trybie jest przekazywanie analizowanego ruchu sieciowego w taki sposób, że klient łączący się z serwerem odwołuje się pod adres interfejsu sieciowego bramy, podłączonego do sieci zewnętrznej, nie znając bezpośredniego adresu tego serwera. Serwer także odwołuje się do klienta, jednakże wykorzystując w tym celu adres interfejsu sieciowego bramy podłączonego do sieci wewnętrznej, nie posiadając tym samym adresu sieciowego klienta.

W niniejszym projekcie implementacji, brama zostanie wdrożona w trybie *Reverse Proxy Kernel.* Kolejnym krokiem w trakcie konfiguracji maszyny wirtualnej za pomocą kreatora jest określenie modelu maszyny w ramach której produkt zostanie zaimplementowany. Poszczególne wersje różnią się pod względem wydajności oraz funkcjonalności, co pozwala na wybór odpowiedniej wersji w zależności od zastosowania (rys. 10)[6].

Specification	Gateways			Management Server
	V4500	V2500	V1000	VM150
Performance				
Number of users included with File Security products	1,000	500	Not applicable	Not applicable
Supported SecureSphere Products	Web Application Firewall Database Activity Monitoring Database Firewall File Activity Monitoring File Firewall	Web Application Firewall Database Activity Monitoring Database Firewall File Activity Monitoring File Firewall	Web Application Firewall	MX Management Server SOM
Minimum Requirements for Physical Host				
Hypervisor	VMWare ESX/ESXi, 4.x and 5.x **Note:** All versions of **SecureSphere SharePoint Security User Guide** support all the versions of ESX/ESXi listed above.			
Processor	Dual-core server Intel VTx or AMD-V			
Memory	See requirements for guest appliances below.			
Hard Drive	DAM - 250GB; WAF - 80GB			
Network Interface	Hypervisor-supported interface card			
Minimum Requirements for each Guest SecureSphere Virtual Appliance				
CPU	4	2	1	2
Memory	8 GB	4 GB	2 GB	4 GB
Disk Space	80 GB	80 GB	80 GB	80 GB

Rys. 10. Wykaz modeli maszyn wirtualnych

Kreator konfiguracji pozwala także na operacje takie jak określenie haseł dostępu do systemu, tworzenie kont użytkowników, czy ustawienie strefy czasowej.

Poprawne wprowadzenie wymaganych parametrów maszyny wirtualnej, umożliwia zakończenie pracy kreatora konfiguracji oraz pierwsze uruchomienie bramy. Ponowne wydanie polecenia „*impcfg*” pozwala na wywołanie ekranu konfiguracyjnego wdrożonej maszyny wirtualnej, w którym możliwa jest konfiguracja podstawowych parametrów ustawionych za pomocą kreatora, konfiguracja parametrów dodatkowych, a także weryfikacja stanu aktualnie wdrożonej bramy (rys. 11).

```
     Configuration target:          local (appliance, V2500, reachable)
     Gateway status:                registered,running
     Setting markers:               C: changed, I: invalid, P: pending (saved b
ut not applied)
     Navigation:                    Top

     Gateway settings
      Gateway name:                 SECURESPHERE_GW
      Gateway mode:                 Reverse Proxy Kernel
      Server address:               11.1.1.2
      'secure' user password:       <is-set>

  1) Manage SecureSphere Management Server.
  2) Manage SecureSphere Gateway.
  3) Manage platform.

  s) Show changes.
  D) Discard changes.

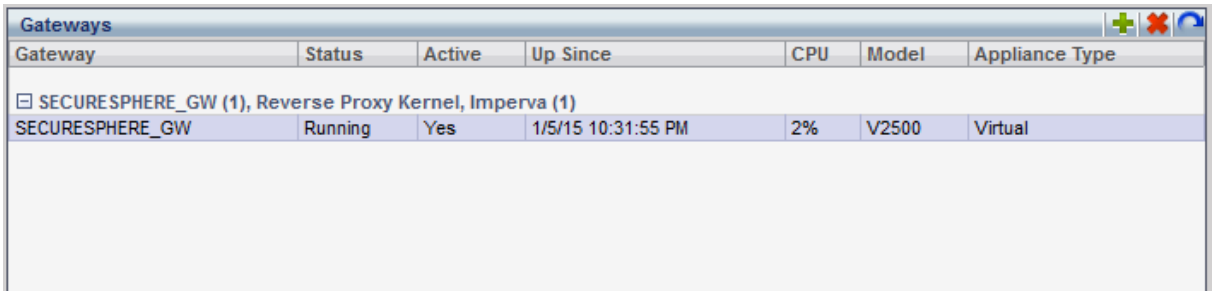
  S) Save settings.
  A) Apply settings.
  q) Quit (discarding not-saved changes).

     Your choice: _
```

Rys. 11. Ekran główny konsolowego ekranu konfiguracyjnego

5.3. Dostosowanie wdrożonego systemu zabezpieczeń

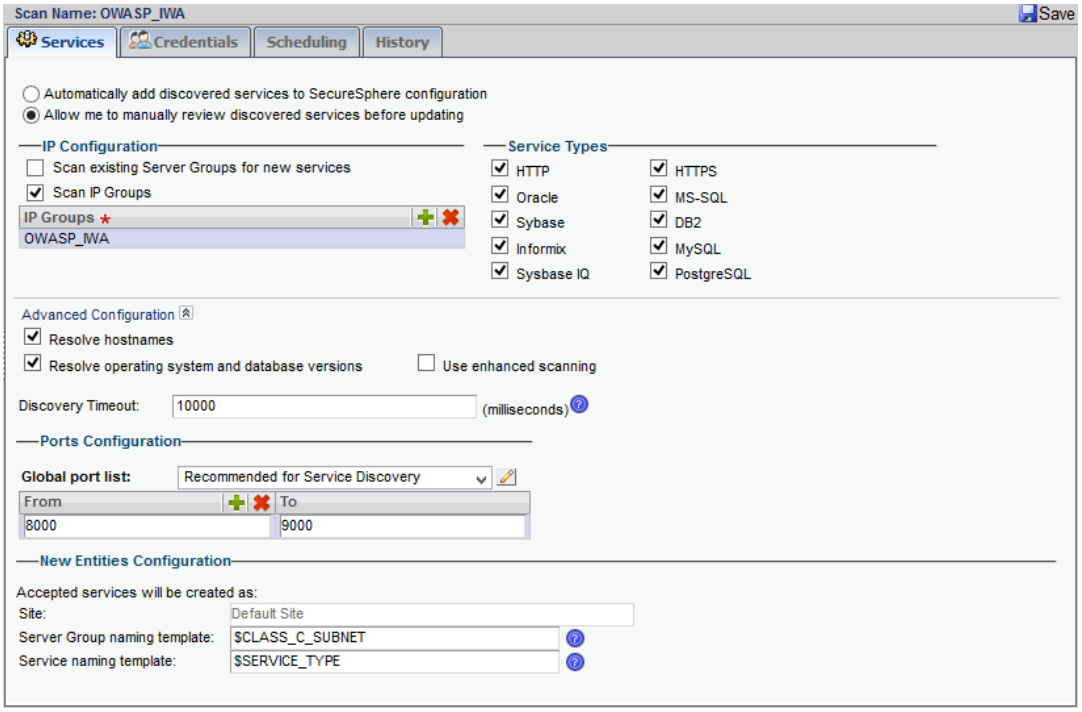
Zakończenie wstępnej konfiguracji maszyny wirtualnej pełniącej funkcję bramy sieciowej umożliwia zestawienie połączenia pomiędzy tą bramą, a serwerem zarządzającym. Celem dalszej konfiguracji niezbędne jest zalogowanie się do panelu administracyjnego serwera zarządzającego za pośrednictwem przeglądarki internetowej. W przypadku implementacji bramy sieciowej w trybie *Kernel Reverse Proxy*, produkt SecureSphere w wersji 10.0 umożliwia zarządzanie interfejsami tej bramy z poziomu interfejsu graficznego, a nie trybu konsolowego, jak w przypadku pozostałych trybów pracy. Po uruchomieniu graficznego panelu administracyjnego i zalogowaniu się za pomocą konta administratora systemu należy przejść do menu „*Setup*", a następnie „*Gateways*". Wybierając odpowiednią grupę skonfigurowanych bram, w tym przypadku „*Reverse Proxy Kernel*", istnieje możliwość określenia aktualnego stanu wybranej bramy (rys. 11), bądź zmiany jej parametrów m.in. adresów sieciowych interfejsów.



Rys. 11. Stan podłączonych bram sieciowych pracujących w trybie „*Reverse Kernel Proxy*"

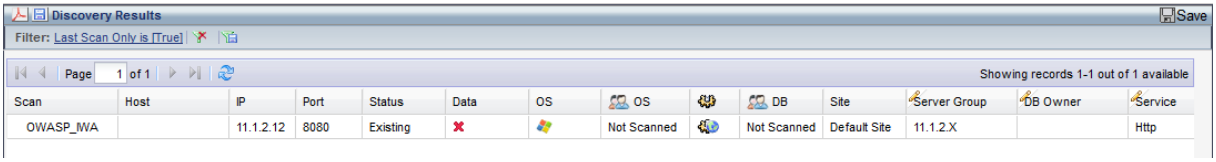
Wykorzystując funkcje „*IP networking*" oraz „*Aliases*" znajdujące się w menu szczegółów wybranej bramy sieciowej administrator może określić adresy IP wykorzystywanych interfejsów sieciowych, a także alias. Alias pozwala na precyzyjne wskazanie interfejsów przyjmujących ruch sieciowy z sieci zewnętrznej, a także przekazujących ruch do sieci wewnętrznej. Wykonanie opisanych czynności konfiguracyjnych jest niezbędne do utworzenia połączenia pomiędzy siecią zewnętrzną oraz wewnętrzną, pozwalającego na filtrowanie ruchu sieciowego i jest konieczne do rozpoczęcia konfiguracji wdrażanych zasad bezpieczeństwa.

Kolejną czynnością w procesie wdrażania systemu zabezpieczeń jest wprowadzenie do produktu SecureSphere profilu zabezpieczanej aplikacji. Omawiany produkt udostępnia narzędzie, które umożliwia automatyczne wykrycie aplikacji webowej oraz określenie jej struktury. Dla poprawnego działania tego narzędzia, należy w menu „*Discovery*" wybrać zakładkę „*Scans*", a następnie utworzyć profil skanowania sieci teleinformatycznej (rys. 12), w którym niezbędne jest wprowadzenie adresu skanowanej sieci lub adresu hosta, na którym zainstalowany jest serwer aplikacji.



Rys. 12. Okno utworzonego profilu skanowania

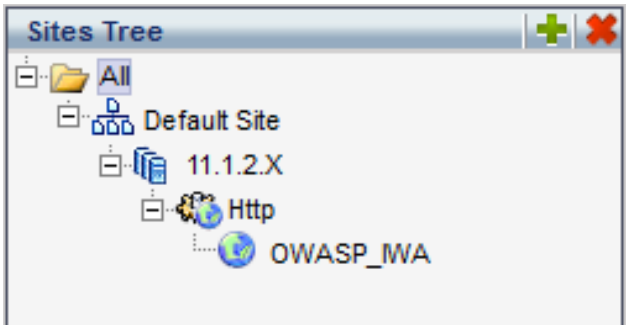
Utworzenie przedstawionego profilu pozwala na rozpoczęcie skanowania sieci teleinformatycznej przez narzędzie SecureSphere, którego wyniki zostaną przedstawione w zakładce „*Discovered Servers*" (rys. 13).



Rys. 13. Podstawowe parametry wykrytego serwera przedstawione w raporcie skanowania

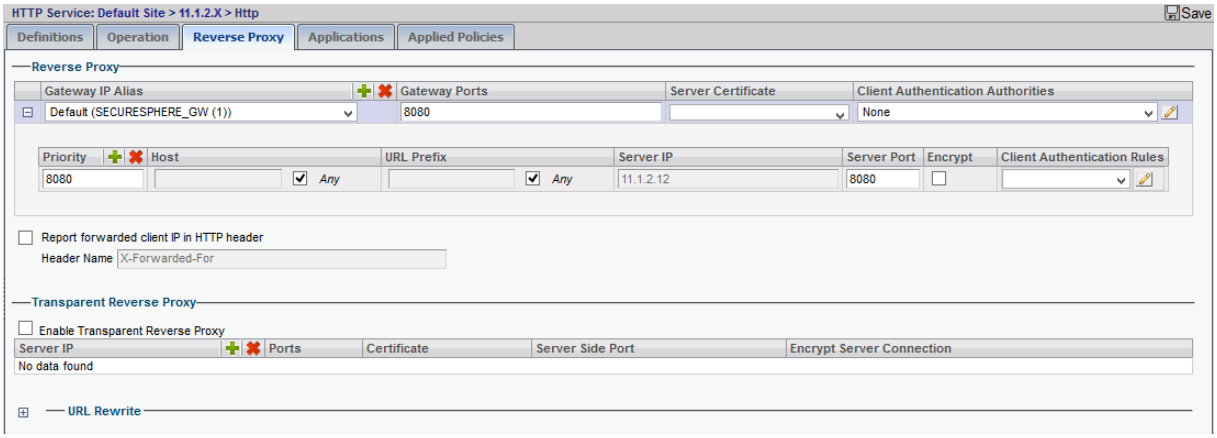
Na podstawie raportu przedstawionego na rysunku 13, można stwierdzić, że wykryty serwer udostępnia usługi za pośrednictwem protokołu *HTTP* i jest dostępny w ramach sieci lokalnej pod adresem *11.1.2.12* na porcie *8080*.

Celem uaktywnienia skonfigurowanej bramy sieciowej i przypisania do niej zabezpieczanej aplikacji internetowej należy przejść do menu „*Setup*", a następnie „*Sites*". Omawiane menu zawiera listę wykrytych aplikacji webowych przedstawioną w postaci rozwijanego drzewa (rys. 14).



Rys. 14. Lista aplikacji internetowych wykrytych przez produkt SecureSphere

Wybierając pozycję „*Http*" z menu przedstawionego na rysunku 14, a następnie zakładkę „*Reverse Proxy*" istnieje możliwość przypisania skonfigurowanej bramy sieciowej do zabezpieczanej aplikacji internetowej (rys. 15).



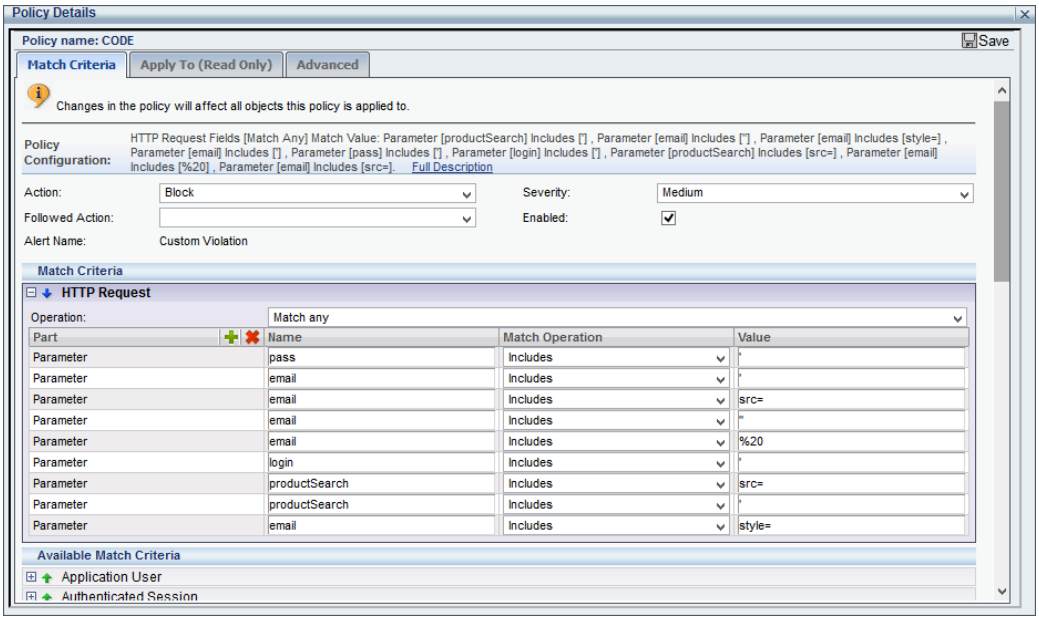
Rys. 15. Przypisanie skonfigurowanej bramy sieciowej do zabezpieczanej aplikacji

Ostatnim krokiem wymaganym do podstawowego zabezpieczenia aplikacji webowej, wykorzystując zasady bezpieczeństwa zaimplementowane w produkcie SecureSphere, jest wybranie z listy przedstawionej na rysunku 14 identyfikatora podsieci, w której znajduje się omawiana aplikacja. Wprowadzenie w sekcji „*Protected IP Addresses*" adresu IP zabezpieczanej aplikacji oraz wybranie z grupy

o nazwie „*Gateway Group*” skonfigurowanej bramy sieciowej pozwala na uruchomienie filtrowania ruchu sieciowego pomiędzy klientem pracującym w sieci zewnętrznej, a serwerem znajdującym się w zabezpieczonej sieci lokalnej. Ruch ten będzie filtrowany, a pakiety uznane na podstawie zasad bezpieczeństwa za niebezpieczne, zostaną odrzucone. Takie działanie zostanie odnotowane w monitorze produktu, który można uruchomić za pomocą menu „*Monitor*”.

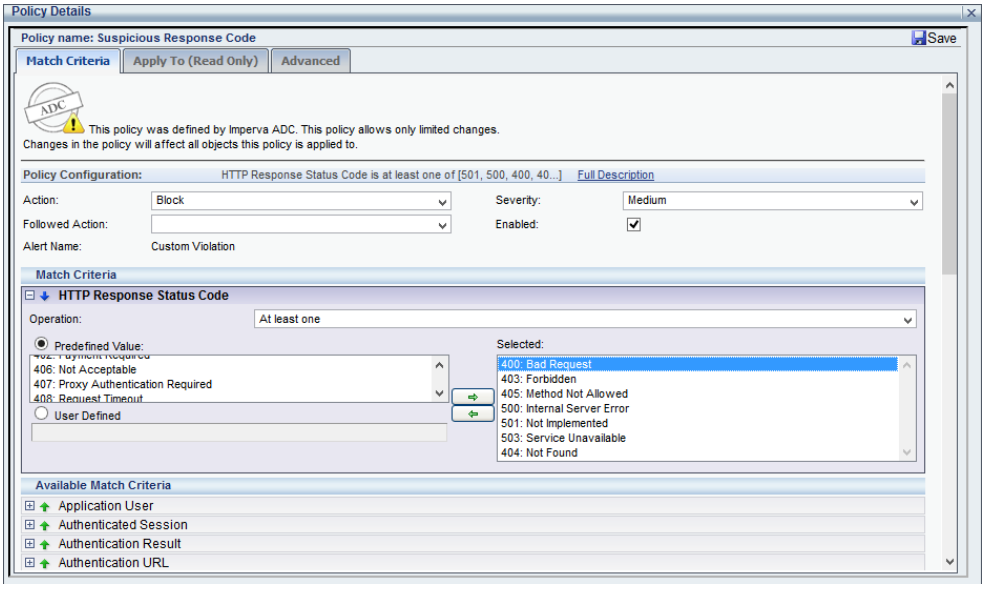
Wraz z instalacją produktu SecureSphere zainstalowane zostają polityki bezpieczeństwa oraz sygnatury ataków przygotowane przez *Imperva ADC*. Elementy te stanowią poziom bazowy ochrony oferowanej przez omawiany system zabezpieczeń. Produkt SecureSphere umożliwia edycję tych elementów, ale w ograniczonym stopniu np. zmianę sposobu reagowania na wykrytą próbę ataku. Należy jednak podkreślić, że użytkownik ma możliwość tworzenia własnych polityk bezpieczeństwa czy sygnatur ataku całkowicie od podstaw, bądź w oparciu o już istniejące. Pozwala to na dostosowanie produktu do potrzeb wynikających z aktualnego stanu podatności zabezpieczanej aplikacji internetowej lub pojawiania się nowych zagrożeń.

Niniejszy projekt implementacji oparty został o wymagania funkcjonalne i niefunkcjonalne zgłoszone przez klienta. Jednym z głównych założeń wdrażanego systemu zabezpieczeń jest ochrona aplikacji webowej przed atakami grupy *Injection* oraz *Cross-Site Scripting*. Pomimo dostarczenia przez produkt SecureSphere podstawowych zasad bezpieczeństwa, niezbędnym jest dostosowanie istniejących zasad lub utworzenie nowych, uwzględniających podatności konkretnej aplikacji, w tym przypadku *OWASP Insecure Web Application*. Na podstawie analizy raportu programu Vega, wygenerowanego w fazie testów penetracyjnych zabezpieczanej aplikacji, utworzona została nowa polityka bezpieczeństwa uwzględniająca podatność omawianej aplikacji na zawartość przekazywanych parametrów w postaci żądań protokołu *HTTP* (rys. 16).



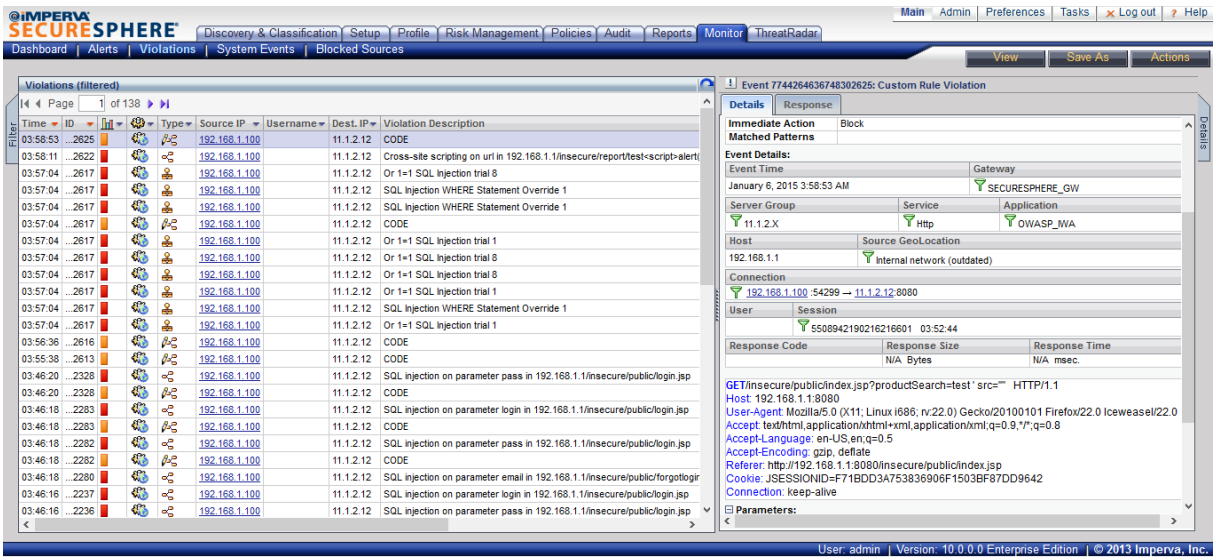
Rys. 16. Parametry utworzonej polityki bezpieczeństwa

Przeprowadzone testy penetracyjne aplikacji *OWASP Insecure Web Application* wykazały, że ta aplikacja jest także podatna na wyświetlanie kodów błędów wygenerowanych po stronie serwera. Produkt SecureSphere zawiera wbudowaną zasadę bezpieczeństwa, chroniącą przed wyświetlaniem występujących błędów, jednakże jest ona domyślnie skonfigurowana tak, aby wyłącznie monitorować i zapisywać informację o takim zdarzeniu. Na potrzeby niniejszego projektu, omawiana zasada została zmodyfikowana tak, aby blokować wyświetlanie takich błędów po stronie klienta (rys. 17).



Rys. 17. Parametry zmodyfikowanej polityki bezpieczeństwa

Jednym z założeń wymagań funkcjonalnych, które zostały wyodrębnione na podstawie żądań klienta jest raportowanie wszelkich zdarzeń takich jak występowanie wyjątków czy naruszeń zabezpieczeń systemu. Wszelkie zdarzenia wykryte przez produkt SecureSphere zapisane zostają w raporcie produktu wraz ze szczegółami tego zdarzenia m.in. godziną i rodzajem zdarzenia, ID sesji użytkownika, wykorzystywanymi parametrami żądań *HTTP* przez użytkownika, a także akcją podjętą przez produkt SecureSphere (rys. 18).



Rys. 18. Okno raportu produktu SecureSphere

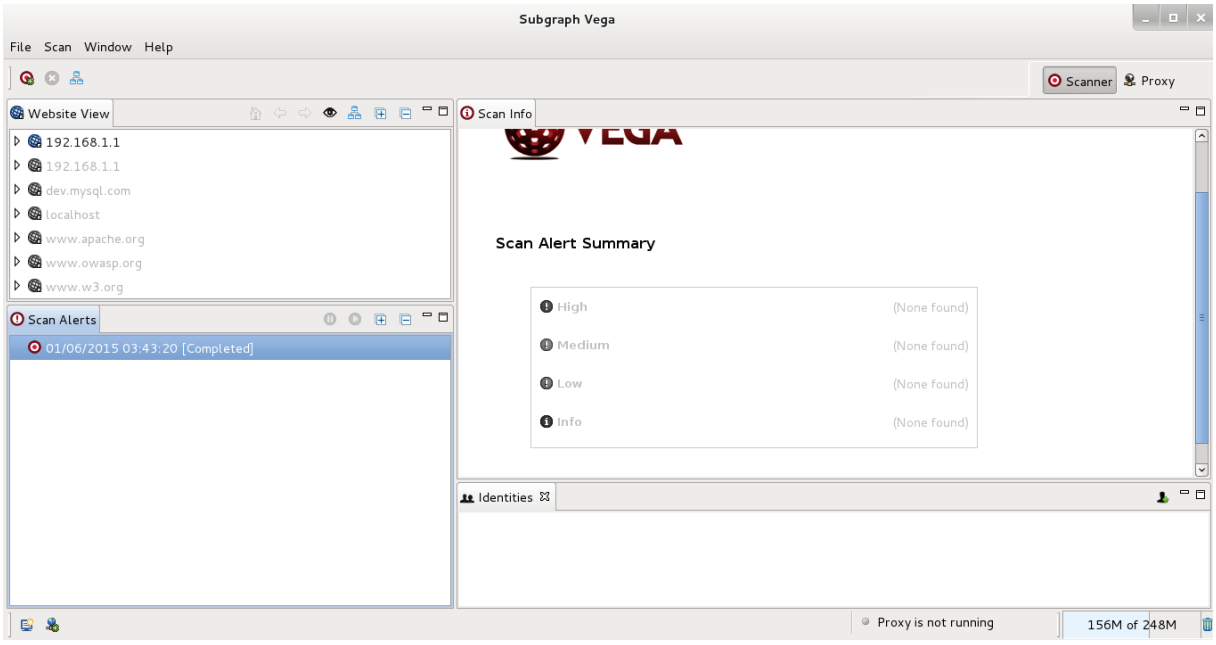
Narzędzie przedstawione na rysunku 18 pozwala administratorowi systemu zabezpieczeń monitorować wszelkie wykryte zdarzenia zawierające znamiona próby przeprowadzenia ataku na aplikację internetową, a także podejmować decyzje dotyczące modyfikowania parametrów zastosowanych zasad bezpieczeństwa.

Rozdział 6
Testowanie systemu

Proces testowania podatności aplikacji na różne ataki jest istotny ze względu na weryfikację skuteczności wdrożonego systemu zabezpieczeń. Takie testy pozwalają na wykrycie ewentualnych luk występujących w zaimplementowanym systemie co umożliwia administratorowi tego systemu rekonfigurację zasad bezpieczeństwa pod kątem wykrytych podatności.

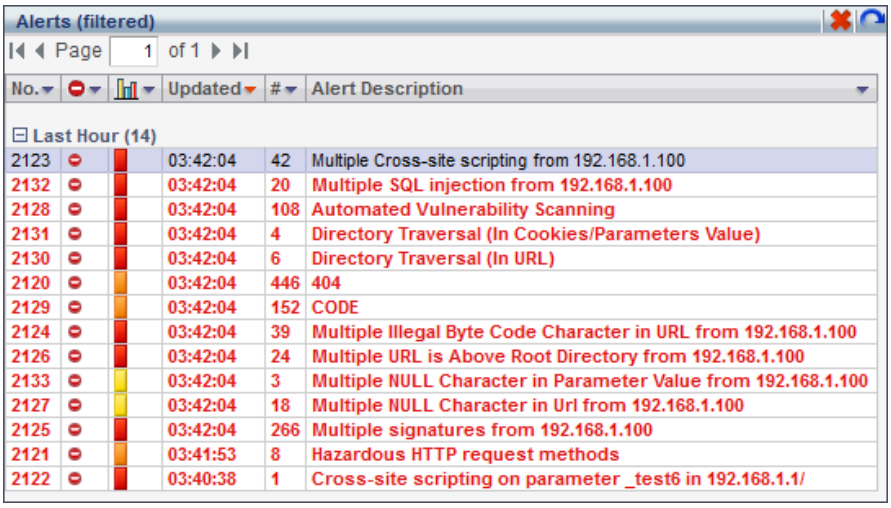
6.1. Badanie podatności zabezpieczonej aplikacji internetowej programem Vega

Pierwszym krokiem w procesie testowania systemu zabezpieczeń jest przeprowadzenie testów penetracyjnych, wykorzystując przeznaczone do tego rodzaju testów oprogramowanie. Celem wykrycia podatności zabezpieczanej aplikacji internetowej na ataki grupy *Injection* oraz *Cross-Site Scripting* użyty został program Vega. Program ten został także użyty na etapie testów wstępnych przed przystąpieniem do implementacji systemu zabezpieczeń. Ponowne wykonanie skanowania, tym razem aplikacji zabezpieczonej poprzez produkt SecureSphere pozwoliło na wygenerowanie nowego, aktualnego raportu programu Vega (rys. 19).



Rys. 19. Raport programu Vega

Wynik przeprowadzonego skanowania omawianej aplikacji webowej przedstawiony na rysunku 19 wskazuje na brak wykrytych pierwotnie podatności. W trakcie testów penetracyjnych, produkt SecureSphere wykrył szereg zdarzeń, będących próbami przeprowadzenia ataku, które zostały zapisane oraz przedstawione w raporcie (rys. 20).



Alerts (filtered)

Page 1 of 1

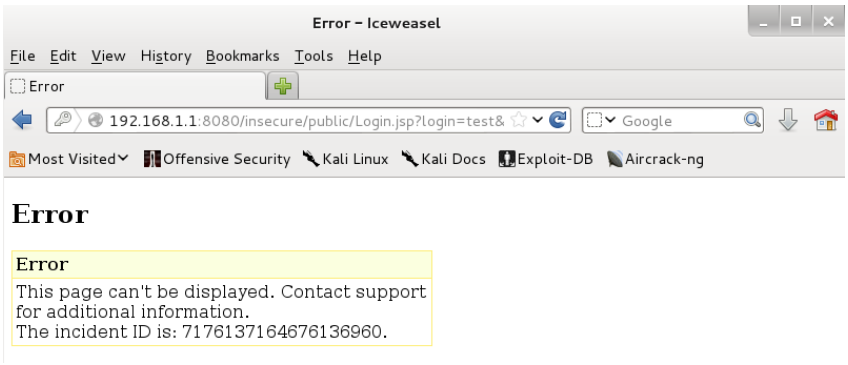
No.			Updated	#	Alert Description
Last Hour (14)					
2123			03:42:04	42	Multiple Cross-site scripting from 192.168.1.100
2132			03:42:04	20	Multiple SQL injection from 192.168.1.100
2128			03:42:04	108	Automated Vulnerability Scanning
2131			03:42:04	4	Directory Traversal (In Cookies/Parameters Value)
2130			03:42:04	6	Directory Traversal (In URL)
2120			03:42:04	446	404
2129			03:42:04	152	CODE
2124			03:42:04	39	Multiple Illegal Byte Code Character in URL from 192.168.1.100
2126			03:42:04	24	Multiple URL is Above Root Directory from 192.168.1.100
2133			03:42:04	3	Multiple NULL Character in Parameter Value from 192.168.1.100
2127			03:42:04	18	Multiple NULL Character in Url from 192.168.1.100
2125			03:42:04	266	Multiple signatures from 192.168.1.100
2121			03:41:53	8	Hazardous HTTP request methods
2122			03:40:38	1	Cross-site scripting on parameter _test6 in 192.168.1.1/

Rys. 20. Raport systemu SecureSphere

Raport produktu SecureSphere zawiera listę wykrytych prób ataku, przeprowadzonych w trakcie działania programu Vega, które skutecznie zostały zablokowane przez system zabezpieczeń. Wśród nich znajdują się m.in. ataki typu *Injection* oraz *Cross-Site Scripting*.

6.2. Próba wyświetlenia kodu błędu serwera

Pomimo braku wykrytych podatności skanowanej aplikacji internetowej, celowym jest ponowne wykonanie ukierunkowanych testów, które zostały przeprowadzone w fazie wstępnego analizowania aplikacji przed wdrożeniem systemu zabezpieczeń. Pierwsza próba dotyczy wywołania kodu błędu serwera w momencie logowania do aplikacji i wyświetlenia go po stronie klienta. W tym celu należy wprowadzić w polu loginu wartość „test”, natomiast w polu hasła „ ‘ ”, a następnie wykonać próbę logowania do systemu (rys. 21).

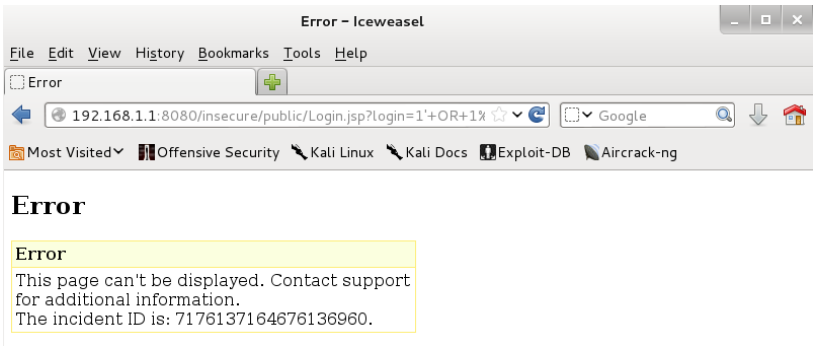


Rys. 21. Komunikat wygenerowany przez produkt SecureSphere

Zrzut ekranu przedstawiony na rysunku 21 zawiera komunikat wygenerowany przez produkt SecureSphere w chwili próby wywołania błędu serwera i wyświetlenia go po stronie klienta. Atak ten został skutecznie zablokowany przez wdrożony system zabezpieczeń.

6.3. Przeprowadzenie ataku z grupy Injection

Kolejny atak dotyczył naruszenia typu *SQL Injection*. Atak ten ma na celu zalogowanie się do aplikacji internetowej, bez znajomości danych logowania użytkowników tej aplikacji. W tym celu, należy w polu login wprowadzić ciąg znaków „*1' OR 1=1 OR '1'='1*", a następnie dokonać próby logowania (rys. 22).

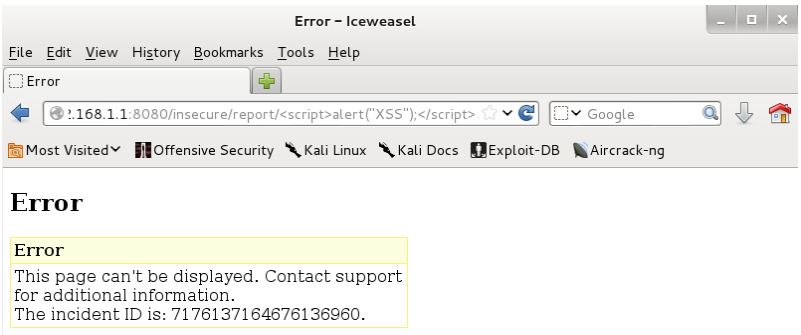


Rys. 22. Komunikat wygenerowany przez produkt SecureSphere

Rysunek 22 przedstawia komunikat wygenerowany przez produkt SecureSphere w momencie próby przeprowadzenia ataku metodą *SQL Injection,* który również został skutecznie zablokowany przez ten produkt.

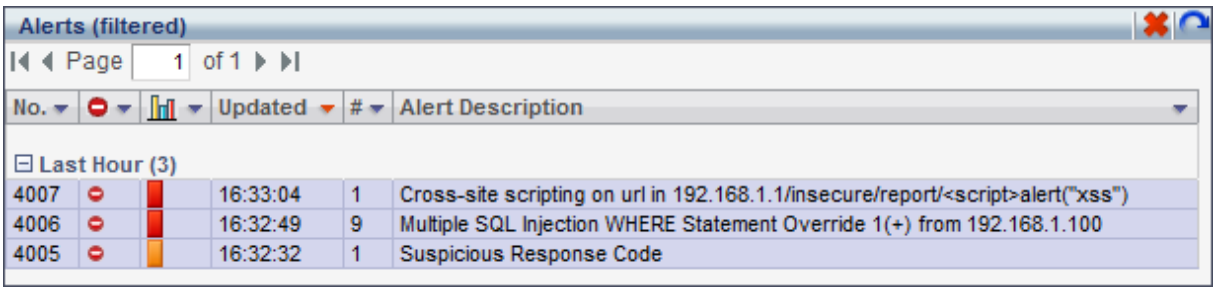
6.4. Przeprowadzenie ataku z grupy Cross-Site Scripting (XSS)

Ostatni z przeprowadzonych ataków, wykorzystuje podatność aplikacji należącą do grupy *Cross-Site Scripting*. Celem tego ataku jest wyświetlenie po stronie klienta aplikacji internetowej komunikatu za pomocą spreparowanego adresu *URL*. Przeprowadzenie ataku *XSS* nie powiodło się, ponieważ został on zablokowany przez system zabezpieczeń, natomiast po stronie klienta został wygenerowany stosowny komunikat informacyjny (rys. 23).



Rys. 23. Komunikat wygenerowany przez produkt SecureSphere

Przeprowadzone ataki zostały wykryte oraz zablokowane przez produkt SecureSphere stanowiący system zabezpieczeń aplikacji *OWASP Insecure Web Application*. Wyniki akcji podjętych przez ten system zostały również zapisane i umieszczone w raporcie, który dostępny jest w ramach panelu administracyjnego produktu (rys. 24).



Rys. 24. Raport systemu SecureSphere

Wnioski końcowe

Przeprowadzone w ramach niniejszej pracy dyplomowej studia literaturowe dotyczące bezpieczeństwa informacji i usług w Internecie, charakterystyki występujących zagrożeń, na które podatne są aplikacje internetowe, a także testowania ich bezpieczeństwa, pozwoliły na pozyskanie i usystematyzowanie wiedzy niezbędnej do opracowania projektu systemu zabezpieczeń omawianych aplikacji.

Cel niniejszej pracy stanowiło opracowanie i implementacja projektu systemu zabezpieczeń aplikacji internetowej z wykorzystaniem rozwiązań firmy Imperva oraz przeprowadzenie testów badających skuteczność wdrożonego systemu. Szczegółowa analiza funkcji i cech produktów oferowanych przez firmę Imperva była podstawą dokonania wyboru produktu SecureSphere Web Application Firewall jako elementu bazowego w implementowanym systemie.

Wykonanie konfiguracji produktu SecureSphere pełniącego rolę filtru ruchu sieciowego, a także przeprowadzenie testów penetracyjnych zabezpieczonej przez ten produkt aplikacji webowej pozwala stwierdzić, że stanowi on skuteczne zabezpieczenie aplikacji internetowych podatnych na zagrożenia wynikające z cyberataków.

Istotną cechą znacznie podnoszącą poziom zabezpieczeń wprowadzonych przez omawiany produkt jest możliwość aktualizowania polityk bezpieczeństwa oraz sygnatur ataków opracowywanych przez *ADC*. Należy także wspomnieć o możliwości tworzenia nowych polityk bezpieczeństwa oraz sygnatur ataków, a także dostosowywania ich do własnych potrzeb.

Pomimo znacznego rozbudowania systemu SecureSphere jest on intuicyjny w obsłudze, co znacznie ułatwia korzystanie z tego produktu. Produkt SecureSphere posiada także obszerny podręcznik użytkowania, który ułatwia zarządzanie jego funkcjami.

Różnorodność trybów wdrożenia urządzenia fizycznego, bądź jego wirtualnej instancji pozwalają na odpowiednie dopasowanie implementowanego systemu do potrzeb zabezpieczanej aplikacji internetowej. Czyni to SecureSphere firmy Im-

perva produktem uniwersalnym w zakresie zabezpieczania omawianych aplikacji, a także skutecznym w działaniu.

Należy jednak zdawać sobie sprawę z ciągłego powstawania nowych zagrożeń, na które narażone są aplikacje webowe, co stanowi wyzwanie dla firmy opracowującej tak zaawansowane systemy zabezpieczeń. W związku z tym za konieczne uważa się stałe prowadzenie analizy pojawiających się zagrożeń dla tych aplikacji, co pozwoli dostosowywać przedmiotowe rozwiązanie do zmieniających się potrzeb użytkowników.

Bibliografia

1. Oficjalna strona internetowa fundacji OWASP, *http://www.owasp.org*
2. Dokument „OWASP Application Security Verification Standard 2009”, Czerwiec 2009r., *http://*owasp-asvs.googlecode.com/files/asvs-webapp-release-2009-pl.pdf
3. Oficjalna strona internetowa firmy Imperva, *http://www.imperva.com*
4. Oficjalna strona firmy Clico, polskiego dystrybutora rozwiązań firmy Imperva, *http://www.clico.pl*
5. Dokument „Imperva SecureSphere Web Security 10.0 User Guide v4.0”, Sierpień 2013r., *http://www.imperva.com*
6. Dokument „Virtual Appliance Configuration Guide 10.0 v4.0”, Sierpień 2013r., *http://www.imperva.com*
7. Andrzej Białas, Bezpieczeństwo informacji i usług w nowoczesnej instytucji i firmie, Wydawnictwo Naukowo-Techniczne, 2009.
8. Paco Hope, Ben Walther, Testowanie Bezpieczeństwa Aplikacji Internetowych, Helion, 2010.

OŚWIADCZENIE

Wyrażam zgodę na udostępnienie mojej pracy przez Bibliotekę Główną WAT w czytelni oraz w ramach wypożyczeń międzybibliotecznych.

Data Podpis